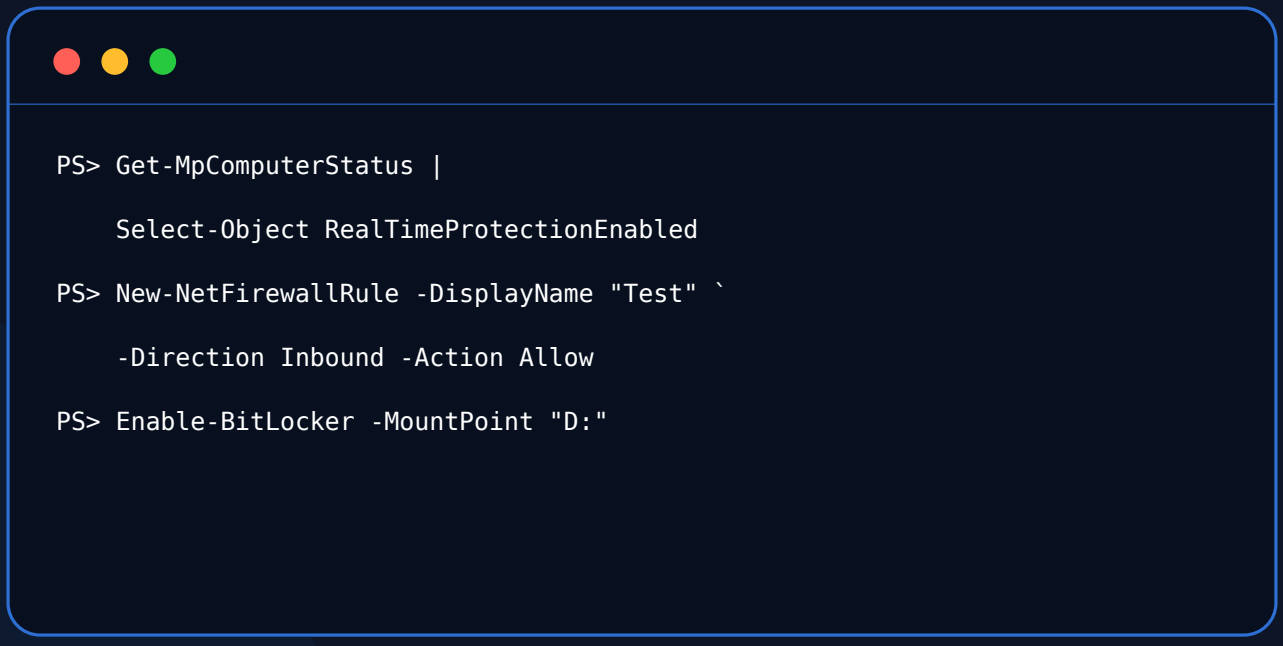
PRAXISHANDBUCH

Windows Security

Band 1: Grundlagen

Windows-Sicherheitsmechanismen verstehen und den eigenen Client absichern



VERSTEHEN, WARUM. NICHT NUR, WELCHEN SCHALTER MAN UMLEGT.

Mit 24 Laborübungen, Kontrollfragen und Lernzielkontrollen · Ausgabe Oktober 2026

Windows Security Band 1: Grundlagen

Windows-Sicherheitsmechanismen verstehen und den eigenen Client absichern

Von Benutzerkonten und UAC über NTFS-Berechtigungen bis zu Defender, Firewall und BitLocker.
Mit 24 Laborübungen auf Windows 11, Kontrollfragen und Lernzielkontrollen je Kapitel.

Inhaltsverzeichnis

Vorwort 7

Zielgruppe und Lernweg 7

Die Laborumgebung dieses Bandes 7

Installation der Laborumgebung 8

Rücksetzung der Laborumgebung 8

Hinweis zu Quellen und Aktualität 8

Kapitel 1: Einführung in Windows Security 9

1. Einführung 9

2. Technische Grundlagen 9

3. Fachbegriffe 9

4. Praxis und Konfiguration 9

5. Sicherheitsbetrachtung 10

6. Praktische Laborübungen 10

7. Typische Fehler 11

8. Zusammenfassung 11

9. Kontrollfragen 11

10. Lernzielkontrolle 11

Kapitel 2: Windows-Systemarchitektur 12

1. Einführung 12

2. Technische Grundlagen 12

3. Fachbegriffe 12

4. Praxis und Konfiguration 12

5. Sicherheitsbetrachtung 13

6. Praktische Laborübungen 13

7. Typische Fehler 14

8. Zusammenfassung 14

9. Kontrollfragen 14

10. Lernzielkontrolle 14

Kapitel 3: Benutzerkonten und Gruppen 15

1. Einführung 15

2. Technische Grundlagen 15

3. Fachbegriffe 15

4. Praxis und Konfiguration . . . 15
5. Sicherheitsbetrachtung . . . 16
6. Praktische Laborübungen . . . 16
7. Typische Fehler . . . 16
8. Zusammenfassung . . . 17
9. Kontrollfragen . . . 17
10. Lernzielkontrolle . . . 17

Kapitel 4: Benutzerrechte und UAC . . . 18

1. Einführung . . . 18
2. Technische Grundlagen . . . 18
3. Fachbegriffe . . . 18
4. Praxis und Konfiguration . . . 18
5. Sicherheitsbetrachtung . . . 19
6. Praktische Laborübungen . . . 19
7. Typische Fehler . . . 20
8. Zusammenfassung . . . 20
9. Kontrollfragen . . . 20
10. Lernzielkontrolle . . . 20

Kapitel 5: NTFS-Berechtigungen und ACL . . . 21

1. Einführung . . . 21
2. Technische Grundlagen . . . 21
3. Fachbegriffe . . . 21
4. Praxis und Konfiguration . . . 21
5. Sicherheitsbetrachtung . . . 22
6. Praktische Laborübungen . . . 22
7. Typische Fehler . . . 23
8. Zusammenfassung . . . 23
9. Kontrollfragen . . . 23
10. Lernzielkontrolle . . . 23

Kapitel 6: Windows-Authentifizierung . . . 24

1. Einführung . . . 24
2. Technische Grundlagen . . . 24
3. Fachbegriffe . . . 24
4. Praxis und Konfiguration . . . 24
5. Sicherheitsbetrachtung . . . 25

6. Praktische Laborübungen . . . 25
7. Typische Fehler . . . 26
8. Zusammenfassung . . . 26
9. Kontrollfragen . . . 26
10. Lernzielkontrolle . . . 27

Kapitel 7: Grundlagen der Netzwerksicherheit . . . 28

1. Einführung . . . 28
2. Technische Grundlagen . . . 28
3. Fachbegriffe . . . 28
4. Praxis und Konfiguration . . . 28
5. Sicherheitsbetrachtung . . . 29
6. Praktische Laborübungen . . . 29
7. Typische Fehler . . . 29
8. Zusammenfassung . . . 29
9. Kontrollfragen . . . 30
10. Lernzielkontrolle . . . 30

Kapitel 8: Windows Defender und Virenschutz . . . 31

1. Einführung . . . 31
2. Technische Grundlagen . . . 31
3. Fachbegriffe . . . 31
4. Praxis und Konfiguration . . . 31
5. Sicherheitsbetrachtung . . . 32
6. Praktische Laborübungen . . . 32
7. Typische Fehler . . . 32
8. Zusammenfassung . . . 33
9. Kontrollfragen . . . 33
10. Lernzielkontrolle . . . 33

Kapitel 9: Windows Defender Firewall . . . 34

1. Einführung . . . 34
2. Technische Grundlagen . . . 34
3. Fachbegriffe . . . 34
4. Praxis und Konfiguration . . . 34
5. Sicherheitsbetrachtung . . . 35
6. Praktische Laborübungen . . . 35
7. Typische Fehler . . . 35

8. Zusammenfassung . . . 35
9. Kontrollfragen . . . 36
10. Lernzielkontrolle . . . 36

Kapitel 10: Windows Updates und Patchmanagement . . . 37

1. Einführung . . . 37
2. Technische Grundlagen . . . 37
3. Fachbegriffe . . . 37
4. Praxis und Konfiguration . . . 37
5. Sicherheitsbetrachtung . . . 38
6. Praktische Laborübungen . . . 38
7. Typische Fehler . . . 38
8. Zusammenfassung . . . 38
9. Kontrollfragen . . . 39
10. Lernzielkontrolle . . . 39

Kapitel 11: Windows-Sicherheitsprotokolle . . . 40

1. Einführung . . . 40
2. Technische Grundlagen . . . 40
3. Fachbegriffe . . . 40
4. Praxis und Konfiguration . . . 40
5. Sicherheitsbetrachtung . . . 40
6. Praktische Laborübungen . . . 41
7. Typische Fehler . . . 41
8. Zusammenfassung . . . 41
9. Kontrollfragen . . . 42
10. Lernzielkontrolle . . . 42

Kapitel 12: Verschlüsselung mit BitLocker . . . 43

1. Einführung . . . 43
2. Technische Grundlagen . . . 43
3. Fachbegriffe . . . 43
4. Praxis und Konfiguration . . . 43
5. Sicherheitsbetrachtung . . . 44
6. Praktische Laborübungen . . . 44
7. Typische Fehler . . . 45
8. Zusammenfassung . . . 45
9. Kontrollfragen . . . 45

10. Lernzielkontrolle 46
Abschlussprojekt Band 1: Sicherer Windows-Arbeitsplatz 46

Verzeichnis der Befehlsbeispiele 47

Index 48

Vorwort

Dieses Buch ist der erste von drei eigenständigen Bänden einer Fachbuchreihe über Windows-Sicherheit. Band 1 vermittelt die Grundlagen: wie Windows-Systeme aufgebaut sind, wie Benutzerkonten, Rechte und Authentifizierung zusammenspielen, wie Defender und Firewall einen Arbeitsplatzrechner grundlegend absichern, und wie Protokollierung und Verschlüsselung als letzte Sicherheitsnetze funktionieren.

Band 2 baut darauf auf und widmet sich der professionellen Härtung in einer Unternehmensumgebung mit Active Directory (Gruppenrichtlinien, Kerberos, Sysmon, Server-Hardening). Band 3 behandelt Sicherheitsanalyse und ethisches Hacking unter Windows (Privilege Escalation, Active-Directory-Angriffe, Metasploit, Incident Response, Forensik). Alle drei Bände bauen aufeinander auf und nutzen dieselbe, wachsende Laborumgebung.

Zielgruppe und Lernweg

Dieses Buch richtet sich an Leser:innen mit Grundkenntnissen der Windows-Bedienung, die systematisch verstehen wollen, warum bestimmte Sicherheitsmaßnahmen notwendig sind, nicht nur, wie man einen Schalter umlegt. Jedes Kapitel erklärt zuerst das Prinzip, dann die konkrete Umsetzung über GUI und PowerShell.

Die Laborumgebung dieses Bandes

Für Band 1 genügt eine einzelne virtuelle Maschine:

System	Rolle	Betriebssystem
CLIENT01	Arbeitsplatzrechner für alle Übungen dieses Bandes	Windows 11 Pro

DC01 (Domänencontroller), SRV01 (Mitgliedsserver), CLIENT02 und KALI01 kommen in Band 2 und 3 hinzu, sobald Active Directory und autorisierte Sicherheitsanalysen eine Rolle spielen.

Beispiel V.1: Netzwerkkonfiguration dieses Bandes

```
CLIENT01   192.168.56.50   (Windows 11 Pro, eigenständig, keine Domäne)
Isoliertes, virtuelles Netzwerk ohne Verbindung zu einem Produktivnetz.
```

> **WARNUNG – Sicherheitsrisiko**
>
> Jede Übung in diesem Buch, die Konfigurationen verändert, gehört ausschließlich in diese isolierte Laborumgebung. Lege vor den Übungen zu Kapitel 9 (Firewall) und 12 (BitLocker) einen Prüfpunkt (Hyper-V-Checkpoint oder vergleichbaren Snapshot) an, bevor du fortfährst.

Installation der Laborumgebung

Beispiel V.2: CLIENT01 einrichten (Kurzübersicht)

```
1. Windows 11 Pro ISO von Microsoft beziehen, in einer virtuellen
   Maschine installieren (Hyper-V, VirtualBox oder VMware)
2. Lokales Konto anlegen, keine Microsoft-Konto-Anmeldung nötig
3. Netzwerkadapter der VM auf ein internes, isoliertes virtuelles
   Netzwerk stellen
4. Windows Update einmal vollständig durchlaufen lassen
```

Rücksetzung der Laborumgebung

Jedes Kapitel kann einzeln geübt werden. Enthält eine Übung eine Konfigurationsänderung, die eine spätere Übung beeinflussen könnte, weist sie ausdrücklich darauf hin. Im Zweifel stellt ein Prüfpunkt-Rücksprung einen sauberen Ausgangszustand wieder her.

Hinweis zu Quellen und Aktualität

Alle PowerShell-Befehle und Konfigurationsschritte in diesem Buch wurden gegen Microsoft Learn und die jeweiligen Produktdokumentationen geprüft. Unterschiede zwischen Windows 11 und Windows Server 2022/2025 werden ausdrücklich gekennzeichnet, sobald sie relevant werden. Dieses Buch ersetzt keine Rechtsberatung und keine offizielle Dokumentation; prüfe bei produktiven Systemen zusätzlich die jeweils aktuelle Quelle.

Kapitel 1: Einführung in Windows Security

Lernziele

- Du kannst erklären, warum Windows-Sicherheit ein eigenständiges Fachgebiet ist.
- Du ordnest ein Sicherheitsrisiko in die CIA-Triade ein.
- Du benennst die wichtigsten Schutzebenen eines modernen Windows-Clients.

1. Einführung

Windows ist das am weitesten verbreitete Betriebssystem auf Arbeitsplatzrechnern weltweit und prägt damit auch die Angriffsfläche, mit der sich die meisten IT-Abteilungen tatsächlich auseinandersetzen. Wer versteht, wie Windows-Sicherheitsmechanismen ineinandergreifen, trifft begründete Entscheidungen statt nur Checklisten abzuarbeiten.

2. Technische Grundlagen

Sicherheit lässt sich, wie bei jedem Betriebssystem, über die **CIA-Triade** beschreiben: Confidentiality (Vertraulichkeit), Integrity (Integrität), Availability (Verfügbarkeit). Eine Firewall-Regel schützt primär Vertraulichkeit und Verfügbarkeit, eine Dateiintegritätsprüfung primär Integrität, ein Backup primär Verfügbarkeit.

Beispiel 1.1: Schutzebenen eines Windows-Clients (Konzept)

```
Benutzerkonten und UAC (Kapitel 3-4)
  -> Dateirechte NTFS (Kapitel 5)
    -> Authentifizierung (Kapitel 6)
      -> Netzwerkschutz: Firewall, Netzwerkprofile (Kapitel 7, 9)
        -> Virenschutz: Defender (Kapitel 8)
          -> Updates (Kapitel 10)
            -> Protokollierung (Kapitel 11)
              -> Verschlüsselung: BitLocker (Kapitel 12)
```

3. Fachbegriffe

Ein **Exploit** nutzt eine konkrete Schwachstelle gezielt aus, eine **Schwachstelle** (Vulnerability) ist die zugrunde liegende Lücke selbst. Ein **CVE** ist eine eindeutige, öffentliche Kennung für eine bekannte Schwachstelle. Microsoft veröffentlicht sicherheitsrelevante Updates traditionell am zweiten Dienstag jedes Monats, dem sogenannten **Patch Tuesday** (vertieft in Kapitel 10).

4. Praxis und Konfiguration

Beispiel 1.2: Grundlegende Systeminformationen abrufen

```
PS> Get-ComputerInfo | Select-Object WindowsProductName, OsVersion, OsBuildNumber
```

Beispiel 1.3: Installierte Software auflisten

```
PS> Get-CimInstance -ClassName Win32_Product | Select-Object Name, Version
```

> **Gut zu wissen**
>
> `Get-CimInstance -ClassName Win32_Product` ist gründlich, aber langsam und kann bei jedem Aufruf eine Reparaturprüfung installierter MSI-Pakete auslösen. Für den alltäglichen, schnelleren Gebrauch eignet sich stattdessen `Get-Package` oder ein Blick in die Registry unter `HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Uninstall`.

5. Sicherheitsbetrachtung

> **WARNUNG – Sicherheitsrisiko**
>
> Ein frisch installiertes Windows 11 ist nicht automatisch vollständig abgesichert. Die Standardeinstellungen bieten einen soliden Basisschutz (Defender und Firewall sind standardmäßig aktiv), aber jede später installierte Software und jedes neu angelegte Konto vergrößert die Angriffsfläche erneut.

6. Praktische Laborübungen

Übung A: Systeminformationen und installierte Software dokumentieren

Aufgabenstellung: Erstelle eine Bestandsaufnahme von CLIENT01. **Ausgangssituation:** CLIENT01 frisch nach Beispiel V.2 installiert. **Voraussetzungen:** PowerShell-Zugriff auf CLIENT01. **Schritt-für-Schritt-Anleitung und Befehle:**

Befehle zu Übung A

```
PS> Get-ComputerInfo | Select-Object WindowsProductName, OsBuildNumber
PS> Get-Package | Select-Object Name, Version | Sort-Object Name
PS> Get-NetFirewallProfile | Select-Object Name, Enabled
```

Erwartetes Ergebnis: Build-Nummer, eine überschaubare Liste vorinstallierter Pakete, alle drei Firewall-Profile als aktiv. **Überprüfung:** Jeder Eintrag lässt sich nachvollziehen, keine unerwartete Drittsoftware. **Fehleranalyse:** Firewall-Profil deaktiviert? Für diese Übungsreihe auf den Standardzustand zurücksetzen. **Musterlösung:** Eine Liste mit Windows-Version, Paketbestand und Firewall-Status als Referenzpunkt für die folgenden Kapitel.

Übung B: Ein aktuelles CVE recherchieren

Aufgabenstellung: Finde für eine auf CLIENT01 vorinstallierte Komponente ein reales CVE. **Ausgangssituation:** Paketliste aus Übung A liegt vor. **Voraussetzungen:** Internetzugang (für die Recherche, nicht zwingend auf CLIENT01 selbst). **Schritt-für-Schritt-Anleitung:** Eine Komponente auswählen (z. B. eine Windows-Teilkomponente), auf msrc.microsoft.com oder über eine öffentliche CVE-Datenbank nachschlagen. **Erwartetes Ergebnis:** Ein konkretes CVE mit Kurzbeschreibung und Status (behoben/offen). **Überprüfung:** Lässt sich aus der Beschreibung ein CIA-Schutzziel ableiten? **Fehleranalyse:** Keine Treffer? Eine größere, bekanntere Komponente wählen (z. B. den Windows-Druckspooler). **Musterlösung:** Eine Lösung nennt CVE-Nummer, betroffene Komponente, Kurzbeschreibung und Status.

7. Typische Fehler

Fehler	Ursache	Behebung
„Windows ist out of the box sicher genug“	Verwechslung von Basisschutz mit vollständiger Absicherung	Bestandsaufnahme aktiv durchführen statt anzunehmen
CIA-Schutzziele nicht unterschieden	Sicherheit nur als „ein“ Ziel gedacht	jede Maßnahme bewusst einem oder mehreren Zielen zuordnen
`Win32_Product` routinemäßig für schnelle Abfragen genutzt	Nebenwirkung unbekannt	für schnelle Abfragen `Get-Package` bevorzugen

8. Zusammenfassung

> **Zusammenfassung**
>
> - Windows-Sicherheit stützt sich wie jedes System auf Vertraulichkeit, Integrität und Verfügbarkeit.
> - Ein moderner Windows-Client schützt sich über mehrere, aufeinander aufbauende Ebenen.
> - CVEs sind eindeutige, öffentliche Kennungen bekannter Schwachstellen.
> - Die eigene Angriffsfläche lässt sich mit PowerShell-Bordmitteln dokumentieren.

9. Kontrollfragen

1. Welche drei Schutzziele bilden die CIA-Triade? (leicht)
2. Was ist der Patch Tuesday? (leicht)
3. Warum gilt eine Standardinstallation von Windows 11 nicht automatisch als vollständig abgesichert? (mittel)
4. Welcher Befehl zeigt installierte Software schneller als `Get-CimInstance -ClassName Win32_Product`? (mittel)
5. Ein Kollege hält Windows Defender und die Firewall für ausreichend, „weil beide standardmäßig aktiv sind“. Was entgegnest du? (schwer)

Lösungshinweise: 1. Confidentiality, Integrity, Availability. 2. Der zweite Dienstag im Monat, an dem Microsoft regelmäßig Sicherheitsupdates veröffentlicht. 3. Weil jede später installierte Software und jedes neue Konto die Angriffsfläche erneut vergrößert. 4. `Get-Package`. 5. Defender und Firewall sind ein solider Basisschutz, aber nur eine von mehreren Ebenen; Benutzerrechte, NTFS-Berechtigungen, Updates und Protokollierung bleiben ebenso notwendig.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] die CIA-Triade ohne Nachschlagen erklären kannst,
- [ ] mit PowerShell eine Systembestandsaufnahme erstellt hast,
- [ ] zu einer selbst gewählten Komponente ein reales CVE gefunden hast,
- [ ] erklären kannst, warum Standardschutz allein nicht ausreicht.

Kapitel 2: Windows-Systemarchitektur

Lernziele

- Du erklärst den Unterschied zwischen Kernel-Mode und User-Mode.
- Du liest den Ausführungskontext eines Windows-Dienstes aus.
- Du nutzt die Registry sicher zur Informationsgewinnung.

1. Einführung

Bevor einzelne Sicherheitsmechanismen sinnvoll erklärbar sind, braucht es ein Grundverständnis für den Aufbau eines laufenden Windows-Systems – vergleichbar mit der Kernel-/Userspace-Trennung unter Linux, hier mit eigenen Begriffen und Werkzeugen.

2. Technische Grundlagen

Windows trennt wie jedes moderne Betriebssystem zwischen **Kernel-Mode** (uneingeschränkter Hardware- und Systemzugriff) und **User-Mode** (eingeschränkte Rechte, Zugriff nur über definierte Schnittstellen). Windows-**Dienste** (Services) laufen oft dauerhaft im Hintergrund, mit einem von drei typischen Konten: `LocalSystem` (umfassende lokale Rechte), `LocalService` (eingeschränkt, nur lokal) oder `NetworkService` (eingeschränkt, mit Netzwerkzugriff).

Beispiel 2.1: Dienste und ihren Ausführungskontext anzeigen

```
PS> Get-CimInstance Win32_Service | Select-Object Name, StartName, State | Sort-Object Name
```

3. Fachbegriffe

Die **Registry** ist die zentrale, hierarchisch aufgebaute Konfigurationsdatenbank von Windows, gegliedert in Stammschlüssel wie `HKEY_LOCAL_MACHINE` (systemweite Einstellungen) und `HKEY_CURRENT_USER` (benutzerbezogene Einstellungen). Ein **Prozess** ist eine laufende Programminstanz mit eigener Prozess-ID und eigenem Sicherheitskontext.

4. Praxis und Konfiguration

Beispiel 2.2: Einen Registry-Schlüssel sicher auslesen

```
PS> Get-ItemProperty -Path "HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion" |
    Select-Object ProductName, CurrentBuild
```

Beispiel 2.3: Laufende Prozesse und ihren Besitzer anzeigen

```
PS> Get-Process | Select-Object Name, Id, `
    @{N='Owner';E={(Get-Process -Id $_.Id -IncludeUserName).UserName}} -First 5
```

Gut zu wissen

> Der Parameter `-IncludeUserName` benötigt eine erhöhte, also als Administrator gestartete PowerShell-Sitzung. Ohne Elevation meldet PowerShell einen Fehler statt die Besitzerspalte zu füllen. Starte PowerShell für dieses Beispiel über „Als Administrator ausführen“.

> **WARNUNG – Sicherheitsrisiko**
>
> Verändere Registry-Werte niemals ohne vorherige Sicherung (Export) des betroffenen Schlüssels. Eine fehlerhafte Änderung kann Windows-Funktionen oder den gesamten Systemstart beeinträchtigen.

5. Sicherheitsbetrachtung

Ein Dienst, der unnötig mit `LocalSystem`-Rechten läuft, vervielfacht den Schaden einer einzelnen Schwachstelle in diesem Dienst, analog zu einem unnötig als root laufenden Linux-Dienst: Ein Angreifer, der über eine Lücke im Dienst Code ausführen kann, erhält dann sofort weitreichende Systemrechte statt eingeschränkter Rechte.

6. Praktische Laborübungen

Übung A: Dienstkontexte systematisch untersuchen

Aufgabenstellung: Ermittle für fünf laufende Dienste auf CLIENT01, mit welchem Konto sie tatsächlich laufen. **Ausgangssituation:** CLIENT01 mit Standarddiensten. **Voraussetzungen:** PowerShell-Zugriff. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 2.1. **Erwartetes Ergebnis:** Eine Übersicht mit Dienstname, Konto und Zustand. **Überprüfung:** Für jeden Dienst lässt sich plausibel begründen, warum er dieses Konto benötigt. **Fehleranalyse:** Unklarer Dienst? Dienstname bei Microsoft Learn oder über `Get-Service -Name <name> | Select-Object DisplayName, Description` nachschlagen. **Musterlösung:** Eine Tabelle mit fünf Diensten, Konto und kurzer Begründung.

Übung B: Einen Registry-Wert sicher auslesen und dokumentieren

Aufgabenstellung: Lies den aktuellen Build-Stand aus der Registry aus und sichere den betroffenen Schlüssel vorab per Export. **Ausgangssituation:** wie Übung A. **Voraussetzungen:** keine besonderen. **Schritt-für-Schritt-Anleitung:**

Befehle zu Übung B

```
PS> reg export "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion" backup.reg
PS> Get-ItemProperty -Path "HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion" |
    Select-Object ProductName, CurrentBuild
```

Erwartetes Ergebnis: Eine Sicherungsdatei `backup.reg` sowie die korrekt ausgelesenen Werte. **Überprüfung:** Die ausgelesene Build-Nummer stimmt mit `Get-ComputerInfo` aus Kapitel 1 überein. **Fehleranalyse:** Zugriff verweigert? PowerShell als Administrator starten. **Musterlösung:** Eine Sicherungsdatei plus dokumentierte, korrekt ausgelesene Werte.

7. Typische Fehler

Fehler	Ursache	Behebung
Dienst unnötig mit LocalSystem-Rechten betrieben	Standardkonfiguration nie hinterfragt	Kontext bei eigenen oder zusätzlich installierten Diensten prüfen
Registry ohne Sicherung verändert	fehlendes Bewusstsein für Risiko	immer zuerst exportieren, dann ändern
`Win32_Product` statt `Get-Package` für schnelle Abfragen genutzt	Kapitel 1 nicht beachtet	schnellere Alternative nutzen

8. Zusammenfassung

> **Zusammenfassung**
>
> - Kernel-Mode hat uneingeschränkten, User-Mode eingeschränkten Zugriff.
> - Windows-Dienste laufen mit unterschiedlichen, unterschiedlich mächtigen Kontexten.
> - Die Registry ist die zentrale Konfigurationsdatenbank und sollte nur mit vorheriger Sicherung verändert werden.
> - Unnötig mächtige Dienstkonten vergrößern den Schaden einer einzelnen Schwachstelle.

9. Kontrollfragen

1. Was unterscheidet Kernel-Mode von User-Mode? (leicht)
2. Nenne die drei typischen Dienstkonten unter Windows. (leicht)
3. Warum sollte vor einer Registry-Änderung immer ein Export erfolgen? (mittel)
4. Welcher Befehl zeigt den Ausführungskontext laufender Dienste? (mittel)
5. Ein eigener, neu installierter Dienst läuft mit `LocalSystem`, obwohl er nur Dateien in einem bestimmten Ordner lesen muss. Wie gehst du vor? (schwer)

Lösungshinweise: 1. Kernel-Mode hat vollen Hardware-/Systemzugriff, User-Mode läuft eingeschränkt. 2. LocalSystem, LocalService, NetworkService. 3. Weil eine fehlerhafte Änderung Systemfunktionen oder den Start beeinträchtigen kann, und ein Export die Wiederherstellung ermöglicht. 4. `Get-CimInstance Win32_Service`. 5. Prüfen, ob der Dienst mit einem eingeschränkteren Konto (z. B. einem eigens angelegten Dienstkonto mit nur Lesezugriff auf den benötigten Ordner) betrieben werden kann, statt pauschal LocalSystem zu belassen.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] den Unterschied zwischen Kernel- und User-Mode erklären kannst,
- [ ] Dienstkontexte mit PowerShell ausgelesen hast,
- [ ] einen Registry-Schlüssel sicher gesichert und ausgelesen hast,
- [ ] ein unnötig mächtiges Dienstkonto als Risiko erkennst.

Kapitel 3: Benutzerkonten und Gruppen

Lernziele

- Du legst lokale Benutzer und Gruppen per PowerShell an.
- Du kennst die wichtigsten integrierten Gruppen und ihre Bedeutung.
- Du prüfst und beschränkst Mitgliedschaft in der Administratoren-Gruppe.

1. Einführung

Wie unter Linux ist auch unter Windows die Benutzerverwaltung das Fundament, auf dem Rechte, Authentifizierung und spätere Domänenanbindung (Band 2) aufbauen.

2. Technische Grundlagen

Jedes Windows-Konto besitzt eine eindeutige **SID** (Security Identifier), das funktionale Gegenstück zur UID unter Linux. Windows bringt integrierte, lokale Gruppen mit: **Administratoren** (volle lokale Rechte), **Benutzer** (eingeschränkte Standardrechte), **Gäste** (stark eingeschränkt, standardmäßig deaktiviert).

Beispiel 3.1: Lokale Benutzer und Gruppen anzeigen

```
PS> Get-LocalUser
PS> Get-LocalGroup
PS> Get-LocalGroupMember -Group "Administratoren"
```

3. Fachbegriffe

Die **lokale Sicherheitsrichtlinie** (`secpol.msc`) konfiguriert lokale Kontorichtlinien wie Passwortanforderungen und Benutzerrechte, bevor in Band 2 Gruppenrichtlinien (GPO) dieselbe Aufgabe zentral für eine ganze Domäne übernehmen. Eine **SID** bleibt auch nach Umbenennung eines Kontos unverändert, da Windows Rechte intern über die SID, nicht den Namen, verwaltet.

4. Praxis und Konfiguration

Beispiel 3.2: Einen lokalen Benutzer und eine Gruppe anlegen

```
PS> New-LocalUser -Name "testuser" -Password `
    (ConvertTo-SecureString "Tr4kt0r!Werk2026" -AsPlainText -Force)
PS> New-LocalGroup -Name "Projekt"
PS> Add-LocalGroupMember -Group "Projekt" -Member "testuser"
```

Gut zu wissen

Das Passwort steht hier nur zu Demonstrationszwecken im Klartext im Beispiel. `-AsPlainText` ist laut Microsoft-Dokumentation nicht für Produktivskripte gedacht, da das Passwort dort unverschlüsselt im Skripttext oder in der Befehlshistorie steht. Frage das Passwort in eigenen Skripten stattdessen interaktiv mit `Read-Host -AsSecureString` ab.

Beispiel 3.3: Mitgliedschaft in der Administratoren-Gruppe prüfen

```
PS> Get-LocalGroupMember -Group "Administratoren"
```

5. Sicherheitsbetrachtung

> **WARNUNG – Sicherheitsrisiko**
>
> Ein Konto, das für den alltäglichen Gebrauch unnötig Mitglied der Administratoren-Gruppe ist, vergrößert die Angriffsfläche erheblich: Jede über dieses Konto ausgeführte Schadsoftware erbt dieselben, weitreichenden Rechte. Nutze für die tägliche Arbeit ein Standardkonto, für administrative Aufgaben ein gesondertes, nur dafür verwendetes Konto.

6. Praktische Laborübungen

Übung A: Lokalen Benutzer und Gruppe anlegen

Aufgabenstellung: Lege einen Benutzer und eine Gruppe nach Beispiel 3.2 an. **Ausgangssituation:** CLIENT01, Standardkonfiguration. **Voraussetzungen:** Administrative PowerShell-Sitzung. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 3.2. **Erwartetes Ergebnis:** `Get-LocalGroupMember -Group "Projekt"` zeigt `testuser`. **Überprüfung:** `Get-LocalUser -Name testuser` bestätigt die Existenz des Kontos. **Fehleranalyse:** Passwort abgelehnt? Windows verlangt standardmäßig eine Mindestkomplexität; ein längeres, gemischtes Passwort verwenden. **Musterlösung:** Benutzer und Gruppe bestehen, die Mitgliedschaft ist korrekt gesetzt.

Übung B: Administratoren-Gruppe prüfen und einschränken

Aufgabenstellung: Prüfe die aktuelle Mitgliedschaft der Administratoren-Gruppe und entferne ein nicht benötigtes Konto (falls vorhanden) oder dokumentiere, warum jedes Mitglied gebraucht wird. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 3.3, danach für jedes Mitglied eine Begründung notieren. **Erwartetes Ergebnis:** Eine vollständige, begründete Liste; `testuser` ist nicht Mitglied. **Überprüfung:** Kein Konto ohne Begründung in der Liste. **Fehleranalyse:** `testuser` versehentlich Mitglied? Mit `Remove-LocalGroupMember -Group "Administratoren" -Member "testuser"` entfernen. **Musterlösung:** Eine dokumentierte, minimal besetzte Administratoren-Gruppe.

7. Typische Fehler

Fehler	Ursache	Behebung
Alltagskonto Mitglied der Administratoren-Gruppe	Bequemlichkeit	Standardkonto für die tägliche Arbeit, separates Admin-Konto für Verwaltung
Konto nach Namen statt SID identifiziert	Unkenntnis des SID-Konzepts	bei Skripten und Rechtevergabe auf die SID verlassen, nicht auf den Namen
Passwort-Komplexität ignoriert	Testpasswort zu einfach gewählt	Mindestanforderungen von Anfang an einhalten

8. Zusammenfassung

> **Zusammenfassung**
>
> - Jedes Konto besitzt eine eindeutige, namensunabhängige SID.
> - Administratoren, Benutzer und Gäste sind die wichtigsten integrierten lokalen Gruppen.
> - Die lokale Sicherheitsrichtlinie ist der Vorläufer der Gruppenrichtlinien aus Band 2.
> - Die Administratoren-Gruppe sollte minimal besetzt bleiben.

9. Kontrollfragen

1. Was ist eine SID? (leicht)
2. Welche drei integrierten lokalen Gruppen wurden genannt? (leicht)
3. Warum bleibt eine SID auch nach Umbenennung eines Kontos unverändert? (mittel)
4. Wozu dient `secpol.msc`? (mittel)
5. Ein Nutzer möchte aus Bequemlichkeit dauerhaft mit einem administrativen Konto arbeiten. Welches Risiko erklärst du ihm konkret? (schwer)

Lösungshinweise: 1. Ein eindeutiger Security Identifier, das Pendant zur UID unter Linux. 2. Administratoren, Benutzer, Gäste. 3. Weil Windows Rechte intern über die SID verwaltet, nicht über den Anzeigenamen. 4. Sie konfiguriert lokale Kontorichtlinien wie Passwortanforderungen und Benutzerrechte. 5. Jede über dieses Konto ausgeführte Schadsoftware oder jeder Bedienfehler erbt dieselben, weitreichenden administrativen Rechte, statt durch ein eingeschränktes Standardkonto begrenzt zu werden.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] einen lokalen Benutzer und eine Gruppe per PowerShell angelegt hast,
- [ ] die Mitgliedschaft der Administratoren-Gruppe geprüft und begründet hast,
- [ ] den Unterschied zwischen SID und Anzeigenamen erklären kannst,
- [ ] das Risiko dauerhafter administrativer Alltagsnutzung einschätzen kannst.

Kapitel 4: Benutzerrechte und UAC

Lernziele

- Du erklärst das Token-Konzept und den Zweck von UAC.
- Du konfigurierst die UAC-Stufe über die lokale Sicherheitsrichtlinie.
- Du beobachtest den Unterschied zwischen Standard- und erhöhtem Token praktisch.

1. Einführung

Kapitel 3 hat gezeigt, warum ein Alltagskonto nicht dauerhaft administrative Rechte haben sollte. **UAC** (User Account Control) löst genau dieses Problem technisch, selbst wenn ein Konto formal zur Administratoren-Gruppe gehört.

2. Technische Grundlagen

Meldet sich ein administratives Konto an, erhält es zwei **Token**: ein eingeschränktes Standard-Token für die normale Nutzung, und ein erhöhtes (elevated) Token, das erst nach ausdrücklicher Bestätigung für eine konkrete, administrative Aktion genutzt wird. Dieses Prinzip heißt **Admin Approval Mode** und ist das technische Gegenstück zum `sudo`-Prinzip unter Linux: nicht dauerhaft erhöhte Rechte, sondern nur für den Moment der tatsächlichen Notwendigkeit.

Beispiel 4.1: Aktuelles Token und Mitgliedschaft prüfen

```
PS> whoami /groups | findstr /i "Mandatory Label"
```

3. Fachbegriffe

Die **UAC-Stufe** legt fest, wie aufdringlich Windows bei einer erhöhten Aktion nachfragt, von „immer benachrichtigen“ bis „nie benachrichtigen“ (nicht empfohlen). Eine **Zustimmungsaufforderung** erscheint für administrative Konten, eine **Anmeldeaufforderung** (mit Passworteingabe) für Standardkonten, die eine administrative Aktion durchführen wollen.

4. Praxis und Konfiguration

Beispiel 4.2: UAC-Stufe über die lokale Sicherheitsrichtlinie einsehen

```
secpol.msc -> Lokale Richtlinien -> Sicherheitsoptionen ->
"Benutzerkontensteuerung: Verhalten der Administratorbestätigungsabfrage..."
```

Beispiel 4.3: UAC-Stufe per PowerShell/Registry auslesen

```
PS> Get-ItemProperty -Path "HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System" `
    -Name ConsentPromptBehaviorAdmin
```

WARNUNG – Sicherheitsrisiko

Setze UAC niemals vollständig auf „nie benachrichtigen“. Das deaktiviert den zentralen Schutz gegen unbemerkte Rechteausweitung durch Schadsoftware, die sich sonst beim Versuch einer administrativen Aktion durch eine Bestätigungsaufforderung verraten würde.

5. Sicherheitsbetrachtung

UAC ist kein Ersatz für ein eingeschränktes Alltagskonto (Kapitel 3), sondern eine zusätzliche Schicht im Sinne von Defense in Depth: Selbst ein administratives Konto läuft im Alltag mit eingeschränktem Token und muss jede erhöhte Aktion ausdrücklich bestätigen.

6. Praktische Laborübungen

Übung A: UAC-Stufe ändern und Wirkung beobachten

WARNUNG – Sicherheitsrisiko

Diese Übung setzt die UAC-Stufe testweise auf die niedrigste Einstellung herab. Das ist eine bewusste, zeitlich eng begrenzte Ausnahme für diese eine Übung, keine empfohlene Dauerkonfiguration. Setze die Stufe unmittelbar nach dem Test wieder zurück.

Aufgabenstellung: Ändere die UAC-Stufe und beobachte den Unterschied beim Start eines administrativen Werkzeugs. **Ausgangssituation:** CLIENT01, UAC in Standardeinstellung. **Voraussetzungen:** administrative Rechte. **Schritt-für-Schritt-Anleitung:** UAC-Stufe über die Systemsteuerung (Benutzerkontensteuerung-Einstellungen ändern) auf die niedrigste Stufe setzen, einen administrativen Vorgang (z. B. `compmgmt.msc` öffnen) testen, danach wieder auf Standard zurücksetzen. **Erwartetes Ergebnis:** Bei niedrigster Stufe erscheint keine sichtbare Bestätigungsaufforderung mehr. **Überprüfung:** Der Unterschied zur Standardeinstellung ist eindeutig beobachtbar. **Fehleranalyse:** Kein Unterschied sichtbar? Neustart oder Abmeldung kann nötig sein, damit die Änderung wirksam wird. **Musterlösung:** Eine dokumentierte Beobachtung beider Einstellungsstufen, mit der UAC-Stufe am Ende wieder auf Standard zurückgesetzt.

Übung B: Standard- und erhöhtes Token vergleichen

Aufgabenstellung: Starte PowerShell einmal regulär, einmal „Als Administrator“, und vergleiche `whoami /groups`. **Ausgangssituation:** wie Übung A, UAC auf Standard zurückgesetzt. **Voraussetzungen:** ein administratives Konto. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 4.1, beide Varianten ausführen. **Erwartetes Ergebnis:** Die administrative Sitzung zeigt ein „High“-Mandatory-Label, die reguläre ein „Medium“-Label. **Überprüfung:** Der Unterschied im Mandatory Label ist eindeutig erkennbar. **Fehleranalyse:** Kein Unterschied? Prüfe, ob PowerShell tatsächlich über „Als Administrator ausführen“ gestartet wurde. **Musterlösung:** Eine dokumentierte Gegenüberstellung beider Token-Zustände.

7. Typische Fehler

Fehler	Ursache	Behebung
UAC vollständig deaktiviert	Bestätigungsaufforderungen als störend empfunden	niedrigere, aber nicht deaktivierte Stufe wählen
UAC mit Administratoren-Gruppenmitgliedschaft verwechselt	Begriffe nicht klar unterschieden	UAC beschränkt die Nutzung von Rechten, ersetzt aber keine Gruppenmitgliedschaft
Änderung nach Test nicht zurückgesetzt	Übung nicht vollständig abgeschlossen	UAC-Stufe am Ende immer wieder auf Standard setzen

8. Zusammenfassung

> **Zusammenfassung**
>
> - UAC trennt Standard- und erhöhtes Token, selbst für administrative Konten.
> - Der Admin Approval Mode entspricht konzeptionell dem `sudo`-Prinzip unter Linux.
> - UAC-Stufen reichen von „immer benachrichtigen“ bis „nie benachrichtigen“, letzteres sollte vermieden werden.
> - UAC ergänzt, ersetzt aber nicht ein eingeschränktes Alltagskonto.

9. Kontrollfragen

1. Was ist der Zweck von UAC? (leicht)
2. Was unterscheidet ein Standard- von einem erhöhten Token? (leicht)
3. Welchem Linux-Konzept entspricht der Admin Approval Mode am ehesten? (mittel)
4. Warum sollte UAC nicht vollständig deaktiviert werden? (mittel)
5. Ein administratives Konto meldet sich normalerweise an und führt den Alltag ohne eine einzige UAC-Abfrage durch. Was schließt du daraus, und was prüfst du als Nächstes? (schwer)

Lösungshinweise: 1. Es schützt vor unbemerkter Rechteausweitung, indem administrative Aktionen ausdrücklich bestätigt werden müssen. 2. Das Standard-Token hat eingeschränkte, das erhöhte volle administrative Rechte für die jeweilige Aktion. 3. Dem `sudo`-Prinzip: nicht dauerhaft erhöhte Rechte, sondern nur für den Moment der Notwendigkeit. 4. Weil sonst Schadsoftware unbemerkt administrative Aktionen durchführen könnte. 5. Das deutet darauf hin, dass UAC möglicherweise auf eine zu niedrige Stufe gesetzt wurde; die aktuelle Konfiguration mit Beispiel 4.3 prüfen.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] die UAC-Stufe geändert und die Wirkung beobachtet hast,
- [ ] Standard- und erhöhtes Token praktisch verglichen hast,
- [ ] das Token-Konzept in eigenen Worten erklären kannst,
- [ ] erklären kannst, warum UAC ein eingeschränktes Alltagskonto ergänzt statt ersetzt.

Kapitel 5: NTFS-Berechtigungen und ACL

Lernziele

- Du unterscheidest NTFS-Berechtigungen von Freigabeberechtigungen.
- Du setzt und vererbst NTFS-Rechte auf einen Ordner.
- Du berechnest effektive Berechtigungen für einen Benutzer mit icacls.

1. Einführung

Wie unter Linux (Band der Schwesterreihe, Kapitel 3) entscheidet auch unter Windows ein Rechtemodell, wer auf welche Datei zugreifen darf. NTFS-Berechtigungen sind dabei feiner gestuft als das klassische Unix-Modell und verdienen eine eigene Betrachtung.

2. Technische Grundlagen

NTFS-Berechtigungen gelten für eine Datei oder einen Ordner unabhängig davon, ob darauf lokal oder über eine Netzwerkfreigabe zugegriffen wird. **Freigabeberechtigungen** gelten zusätzlich nur für den Netzwerkzugriff über eine Freigabe; bei einer Kombination beider gilt stets die jeweils restriktivere Einstellung.

Beispiel 5.1: NTFS-Rechte eines Ordners anzeigen

```
PS> icacls C:\Projekt
```

3. Fachbegriffe

Vererbung überträgt die Rechte eines übergeordneten Ordners automatisch auf neu erstellte Unterordner und Dateien, sofern nicht ausdrücklich unterbrochen. **Effektive Berechtigungen** sind das tatsächliche Ergebnis aus expliziten Rechten, geerbten Rechten und Gruppenmitgliedschaften eines Benutzers, kombiniert.

4. Praxis und Konfiguration

Beispiel 5.2: NTFS-Rechte gezielt setzen

```
PS> icacls C:\Projekt /grant "Projekt:(OI)(CI)M"
```

Kürzel	Bedeutung
`M`	Modify (Ändern)
`(OI)`	Object Inherit, gilt für neue Dateien im Ordner
`(CI)`	Container Inherit, gilt für neue Unterordner

Beispiel 5.3: Effektive Berechtigungen eines Benutzers prüfen (GUI)

```
Ordnereigenschaften -> Sicherheit -> Erweitert -> "Effektiver Zugriff"
-> Benutzer auswählen -> Zugriff anzeigen
```

5. Sicherheitsbetrachtung

> **WARNUNG – Sicherheitsrisiko**
>
> Eine unterbrochene Vererbung ohne Dokumentation führt häufig zu unübersichtlichen, schwer nachvollziehbaren Rechtestrukturen. Dokumentiere jede bewusste Abweichung von der Vererbung, insbesondere bei Ordnern mit sensiblen Daten.

6. Praktische Laborübungen

Übung A: NTFS-Rechte setzen und vererben lassen

Aufgabenstellung: Lege einen Ordner an, setze Rechte für die Gruppe „Projekt“ aus Kapitel 3, und bestätige die Vererbung auf eine neue Unterdatei. **Ausgangssituation:** Gruppe „Projekt“ aus Kapitel 3 vorhanden. **Voraussetzungen:** administrative Rechte. **Schritt-für-Schritt-Anleitung:**

Befehle zu Übung A

```
PS> New-Item -ItemType Directory -Path C:\Projekt
PS> icacls C:\Projekt /grant "Projekt:(OI)(CI)M"
PS> New-Item -ItemType File -Path C:\Projekt\test.txt
PS> icacls C:\Projekt\test.txt
```

Erwartetes Ergebnis: `test.txt` zeigt dieselben, geerbten Rechte für die Gruppe „Projekt“. **Überprüfung:** Die Ausgabe von `icacls` enthält den Vererbungsvermerk. **Fehleranalyse:** Keine Vererbung sichtbar? Prüfe, ob `(OI)(CI)` korrekt gesetzt wurde. **Musterlösung:** Eine Datei mit korrekt geerbten Rechten, bestätigt durch `icacls`.

Übung B: Effektive Berechtigungen berechnen

Aufgabenstellung: Berechne die effektiven Berechtigungen von `testuser` für den Ordner aus Übung A. **Ausgangssituation:** Ergebnis aus Übung A, `testuser` ist Mitglied der Gruppe „Projekt“. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 5.3, mit `testuser` als geprüftem Benutzer. **Erwartetes Ergebnis:** Die effektiven Rechte entsprechen den über die Gruppe vergebenen, geerbten Rechten. **Überprüfung:** Keine unerwartete Abweichung zwischen vergebenen und effektiven Rechten. **Fehleranalyse:** Abweichung gefunden? Nach einer zusätzlichen, expliziten Verweigerung für dieses Konto oder eine andere Gruppe suchen. **Musterlösung:** Eine dokumentierte Übereinstimmung zwischen vergebenen und effektiven Rechten.

7. Typische Fehler

Fehler	Ursache	Behebung
NTFS- und Freigabeberechtigungen verwechselt	Begriffe nicht klar unterschieden	beide separat prüfen, restriktivere gilt
Vererbung ohne Dokumentation unterbrochen	spontane Einzelentscheidung	jede Abweichung schriftlich begründen
Rechte nur vermutet, nie mit icacls verifiziert	GUI-Ansicht als ausreichend angenommen	`icacls` zusätzlich zur Bestätigung nutzen

8. Zusammenfassung

> **Zusammenfassung**
>
> - NTFS-Berechtigungen gelten unabhängig vom Zugriffsweg, Freigabeberechtigungen nur zusätzlich für Netzwerkzugriff.
> - Bei einer Kombination gilt stets die restriktivere Einstellung.
> - Vererbung überträgt Rechte automatisch auf neue Unterobjekte, sofern nicht unterbrochen.
> - Effektive Berechtigungen lassen sich gezielt für einen Benutzer berechnen und prüfen.

9. Kontrollfragen

1. Was unterscheidet NTFS- von Freigabeberechtigungen? (leicht)
2. Welches Kommandozeilenwerkzeug verwaltet NTFS-Rechte? (leicht)
3. Welche Regel gilt, wenn NTFS- und Freigabeberechtigungen unterschiedlich restriktiv sind? (mittel)
4. Was bedeuten die Kürzel `(OI)` und `(CI)`? (mittel)
5. Ein Benutzer hat laut expliziter NTFS-Berechtigung Vollzugriff, meldet aber, keinen Zugriff zu haben. Welche zwei Ursachen prüfst du zuerst? (schwer)

Lösungshinweise: 1. NTFS gilt unabhängig vom Zugriffsweg, Freigabeberechtigungen nur zusätzlich beim Netzwerkzugriff. 2. `icacls`. 3. Die jeweils restriktivere Einstellung gilt. 4. `(OI)` vererbt an neue Dateien, `(CI)` an neue Unterordner. 5. Erstens, ob eine Freigabeberechtigung die NTFS-Rechte zusätzlich einschränkt; zweitens, ob eine andere Gruppenmitgliedschaft des Benutzers eine explizite Verweigerung mitbringt, die Vorrang vor einer Erlaubnis hat.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] NTFS-Rechte gesetzt und die Vererbung bestätigt hast,
- [ ] effektive Berechtigungen für einen Benutzer berechnet hast,
- [ ] NTFS- und Freigabeberechtigungen klar unterscheiden kannst,
- [ ] eine unerwartete Zugriffsverweigerung systematisch eingrenzen kannst.

Kapitel 6: Windows-Authentifizierung

Lernziele

- Du unterscheidest lokale Anmeldung von Domänenanmeldung konzeptionell.
- Du verwaltest gespeicherte Zugangsdaten im Credential Manager.
- Du richtest Windows Hello als modernen Authentifizierungsfaktor ein.

1. Einführung

Kapitel 3 hat Konten angelegt, Kapitel 4 ihre Rechte eingeschränkt. Dieses Kapitel behandelt, wie Windows die Identität einer Person überhaupt prüft, bevor Band 2 denselben Vorgang für eine ganze Domäne vertieft.

2. Technische Grundlagen

Eine **lokale Anmeldung** prüft Zugangsdaten gegen die lokale Kontendatenbank (SAM) desselben Rechners. Eine **Domänenanmeldung** (Band 2) prüft stattdessen gegen einen zentralen Domänencontroller über Kerberos oder NTLM. Für Band 1 bleibt nur die lokale Anmeldung relevant.

Beispiel 6.1: Aktuelle Anmeldesitzung anzeigen

```
PS> whoami /logonid
PS> query user
```

3. Fachbegriffe

Der **Credential Manager** speichert Zugangsdaten für Netzwerkressourcen und Webanwendungen zentral und verschlüsselt, damit sie nicht bei jeder Nutzung erneut eingegeben werden müssen. **Windows Hello** erlaubt die Anmeldung über biometrische Merkmale oder eine PIN, die an das jeweilige Gerät gebunden ist, statt ein über Netzwerke übertragbares Passwort zu nutzen.

4. Praxis und Konfiguration

Beispiel 6.2: Credential Manager einsehen

```
control /name Microsoft.CredentialManager
```

Beispiel 6.3: Gespeicherte Zugangsdaten per PowerShell auflisten

```
PS> cmdkey /list
```

Beispiel 6.4: Windows Hello einrichten

```
Einstellungen -> Konten -> Anmeldeoptionen -> Windows Hello
-> PIN oder Gesichtserkennung/Fingerabdruck (bei vorhandener Hardware) einrichten
```

5. Sicherheitsbetrachtung

Gut zu wissen

Eine Windows-Hello-PIN ist trotz ihrer scheinbaren Einfachheit sicherheitstechnisch stärker als ein Passwort, weil sie an das spezifische Trusted-Platform-Module (TPM) des jeweiligen Geräts gebunden ist: Ein auf einem anderen Gerät abgefangener PIN-Wert lässt sich dort nicht verwenden, anders als ein gestohlenes Passwort.

WARNUNG – Sicherheitsrisiko

Im Credential Manager gespeicherte Zugangsdaten sind für jede Anwendung zugänglich, die mit den Rechten des angemeldeten Benutzers läuft. Entferne nicht mehr benötigte, gespeicherte Zugangsdaten regelmäßig.

6. Praktische Laborübungen

Übung A: Credential Manager prüfen und bereinigen

WARNUNG – Sicherheitsrisiko

`cmdkey /add` übergibt das Passwort als sichtbares Befehlszeilenargument. Es erscheint damit unverschlüsselt in der PowerShell-Verlaufsdatei (PSReadLine) und ist für jeden Prozess sichtbar, der die Befehlszeile eines anderen Prozesses einsehen kann. Dieser Weg eignet sich deshalb nur für einen kurzlebigen Test in dieser isolierten Übung, niemals für den produktiven Gebrauch. Nutze dort stattdessen den Credential-Manager-Dialog (Beispiel 6.2) mit seiner maskierten Eingabe, oder frage Zugangsdaten interaktiv mit `Get-Credential` ab.

Aufgabenstellung: Liste gespeicherte Zugangsdaten auf und entferne einen nicht mehr benötigten Testeintrag. **Ausgangssituation:** CLIENT01, ggf. mit Testeintrag. **Voraussetzungen:** keine besonderen. **Schritt-für-Schritt-Anleitung:**

Befehle zu Übung A

```
PS> cmdkey /add:testserver /user:testuser /pass:Testpasswort123!
PS> cmdkey /list
PS> cmdkey /delete:testserver
```

Erwartetes Ergebnis: Der Testeintrag erscheint nach dem Anlegen und ist nach dem Löschen nicht mehr vorhanden. **Überprüfung:** `cmdkey /list` bestätigt beide Zustände. **Fehleranalyse:** Eintrag nicht gelöscht? Exakten Namen aus `/list` für `/delete` verwenden. **Musterlösung:** Eine bereinigte Liste gespeicherter Zugangsdaten ohne Testeinträge. Lösche nach der Übung zusätzlich den entsprechenden Eintrag aus der PowerShell-Verlaufsdatei (`Clear-History` wirkt nur auf die aktuelle Sitzung; die persistente Datei liegt unter `(Get-PSReadLineOption).HistorySavePath`), falls die Sitzung über diese Übung hinaus fortgesetzt wird.

Übung B: Windows Hello einrichten und testen

Aufgabenstellung: Richte eine Windows-Hello-PIN ein und melde dich testweise damit an. **Ausgangssituation:** CLIENT01 mit einem lokalen Konto. **Voraussetzungen:** keine spezielle Hardware für eine PIN nötig. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 6.4. **Erwartetes Ergebnis:** Eine erfolgreiche Anmeldung mit der neu eingerichteten PIN statt des Passworts. **Überprüfung:** Die Anmeldung funktioniert zuverlässig mit der PIN. **Fehleranalyse:** Option nicht verfügbar? Prüfen, ob TPM in der virtuellen Maschine aktiviert ist (bei Hyper-V: „Sicherheit“ in den VM-Einstellungen). **Musterlösung:** Eine funktionierende PIN-Anmeldung, dokumentiert mit Begründung des Sicherheitsvorteils gegenüber einem Passwort.

7. Typische Fehler

Fehler	Ursache	Behebung
Testzugangsdaten im Credential Manager vergessen	fehlende Bereinigung nach Übung	nicht mehr benötigte Einträge aktiv entfernen
Windows Hello mit Passwort-Ersatz über das Netz verwechselt	Missverständnis der Gerätebindung	PIN gilt ausschließlich lokal für dieses eine Gerät
TPM in der VM nicht aktiviert	Standardeinstellung der Virtualisierung übersehen	VM-Sicherheitseinstellungen vor der Übung prüfen

8. Zusammenfassung

Zusammenfassung

- Lokale Anmeldung prüft gegen die lokale Kontendatenbank, Domänenanmeldung gegen einen Domänencontroller.
- Der Credential Manager speichert Zugangsdaten zentral und verschlüsselt.
- Windows Hello bindet die Anmeldung an das jeweilige Gerät statt an ein übertragbares Passwort.
- Nicht mehr benötigte, gespeicherte Zugangsdaten sollten regelmäßig entfernt werden.

9. Kontrollfragen

1. Wogegen prüft eine lokale Anmeldung die Zugangsdaten? (leicht)
2. Was speichert der Credential Manager? (leicht)
3. Warum ist eine Windows-Hello-PIN sicherer als ein klassisches Passwort? (mittel)
4. Welcher Befehl listet gespeicherte Zugangsdaten auf? (mittel)
5. Ein Nutzer möchte dieselbe Windows-Hello-PIN auf einem zweiten Gerät verwenden. Funktioniert das, und warum? (schwer)

Lösungshinweise: 1. Gegen die lokale Kontendatenbank (SAM) desselben Rechners. 2. Zugangsdaten für Netzwerkressourcen und Webanwendungen, zentral und verschlüsselt. 3. Weil sie an das TPM des jeweiligen Geräts gebunden ist und auf einem anderen Gerät nicht funktioniert. 4. `cmdkey /list`. 5. Nein, eine Windows-Hello-PIN ist geräte-, nicht kontogebunden; auf dem zweiten Gerät muss eine eigene, neue PIN eingerichtet werden.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] den Credential Manager geprüft und bereinigt hast,
- [ ] Windows Hello erfolgreich eingerichtet hast,
- [ ] den Unterschied zwischen lokaler und Domänenanmeldung erklären kannst,
- [ ] begründen kannst, warum eine PIN gerätegebunden sicherer ist als ein Passwort.

Kapitel 7: Grundlagen der Netzwerksicherheit

Lernziele

- Du erklärst die drei Windows-Netzwerkprofile und ihre sicherheitsrelevante Wirkung.
- Du liest offene Verbindungen und lauschende Ports mit PowerShell aus.
- Du ordnest Netzwerkerkennung und Dateifreigabe als typische Angriffsflächen ein.

1. Einführung

Jeder Netzwerkdienst, der auf CLIENT01 lauscht, ist ein potenzieller Zugangspunkt. Dieses Kapitel macht sichtbar, was überhaupt gefiltert werden soll, bevor Kapitel 9 die Firewall-Konfiguration behandelt.

2. Technische Grundlagen

Windows ordnet jede Netzwerkverbindung einem von drei **Netzwerkprofilen** zu: **Öffentlich** (restriktiv, für unbekannte Netze), **Privat** (vertrauenswürdiger, für Heimnetze) und **Domäne** (automatisch bei Domänenmitgliedschaft, Band 2). Die Firewall-Regeln aus Kapitel 9 gelten jeweils pro Profil unterschiedlich.

Beispiel 7.1: Aktuelles Netzwerkprofil anzeigen

```
PS> Get-NetConnectionProfile
```

3. Fachbegriffe

Netzwerkerkennung (Network Discovery) macht einen Rechner für andere Geräte im selben Netz sichtbar und erlaubt umgekehrt, andere Geräte zu finden – praktisch in vertrauenswürdigen Netzen, aber unnötige Angriffsfläche in öffentlichen. **SMB** (Server Message Block) ist das Windows-Protokoll für Datei- und Druckerfreigaben und historisch Ziel zahlreicher Schwachstellen.

4. Praxis und Konfiguration

Beispiel 7.2: Lauschende Ports und zugehörige Prozesse anzeigen

```
PS> Get-NetTCPConnection -State Listen | Select-Object LocalAddress, LocalPort, OwningProcess
```

Beispiel 7.3: Prozessnamen zu einer gefundenen PID auflösen

```
PS> Get-Process -Id <PID> | Select-Object Name, Path
```

Beispiel 7.4: Netzwerkprofil eines Adapters ändern

```
PS> Set-NetConnectionProfile -InterfaceAlias "Ethernet" -NetworkCategory Private
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Setze das Netzwerkprofil eines unbekannten oder öffentlichen Netzes (z. B. an einem Flughafen) niemals auf „Privat“. Das öffentliche Profil aktiviert automatisch restriktivere Firewall-Regeln, die genau für solche Umgebungen gedacht sind.

6. Praktische Laborübungen

Übung A: Lauschende Ports vollständig dokumentieren

Aufgabenstellung: Erstelle eine vollständige, begründete Liste aller lauschenden Ports auf CLIENT01. **Ausgangssituation:** CLIENT01 nach Kapitel 1-6. **Voraussetzungen:** PowerShell-Zugriff. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 7.2, 7.3. **Erwartetes Ergebnis:** Eine Tabelle mit Port, Prozess und Begründung. **Überprüfung:** Jeder gefundene Port hat einen Eintrag. **Fehleranalyse:** Prozessname unklar? Pfad aus Beispiel 7.3 bei Microsoft Learn nachschlagen. **Musterlösung:** Eine vollständige, dokumentierte Portliste.

Übung B: Netzwerkprofil und seine Wirkung beobachten

Aufgabenstellung: Wechsle das Netzwerkprofil testweise und beobachte die Auswirkung auf Netzwerkerkennung und Firewall-Status. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** Profil mit `Get-NetConnectionProfile` prüfen, testweise mit Beispiel 7.4 wechseln, Netzwerkerkennungs-Einstellung in der Systemsteuerung vergleichen. **Erwartetes Ergebnis:** Im „Privat“-Profil ist Netzwerkerkennung standardmäßig aktivierbar, im „Öffentlich“-Profil deaktiviert. **Überprüfung:** Die Einstellung in der Systemsteuerung entspricht dem gewählten Profil. **Fehleranalyse:** Keine Änderung sichtbar? Adapter-Namen mit `Get-NetAdapter` prüfen. **Musterlösung:** Eine dokumentierte Gegenüberstellung beider Profile und ihrer jeweiligen Netzwerkerkennungs-Einstellung.

7. Typische Fehler

Fehler	Ursache	Behebung
Öffentliches Netz fälschlich als „Privat“ eingestuft	Bequemlichkeit oder Unwissen	Profil nur für tatsächlich vertrauenswürdige Netze auf „Privat“ setzen
Unbekannter, lauschender Port übersehen	Angriffsfläche nicht dokumentiert	regelmäßig `Get-NetTCPConnection` gegen die eigene Dokumentation abgleichen
SMB als „nur intern, also unkritisch“ abgetan	fehlende Risikoeinschätzung	SMB-Exposition insbesondere in öffentlichen Netzen besonders kritisch prüfen

8. Zusammenfassung

Zusammenfassung

- Windows ordnet Verbindungen den Profilen Öffentlich, Privat oder Domäne zu, mit jeweils unterschiedlicher Firewall-Wirkung.

- `Get-NetTCPConnection` macht lauschende Ports und zugehörige Prozesse sichtbar.
- Netzwerkerkennung und SMB sind typische, profilabhängige Angriffsflächen.
- Das Netzwerkprofil sollte nie leichtfertig auf „Privat“ gesetzt werden.

9. Kontrollfragen

1. Welche drei Netzwerkprofile kennt Windows? (leicht)
2. Welcher Befehl zeigt lauschende Ports? (leicht)
3. Warum ist Netzwerkerkennung in öffentlichen Netzen riskant? (mittel)
4. Wofür steht SMB? (mittel)
5. Ein Laptop wechselt häufig zwischen Heim- und öffentlichem WLAN. Welche Konsequenz hat das für die Firewall-Konfiguration, und warum ist das eigentlich praktisch? (schwer)

Lösungshinweise: 1. Öffentlich, Privat, Domäne. 2. `Get-NetTCPConnection -State Listen`. 3. Weil sie den Rechner für beliebige, unbekannte Geräte im selben Netz sichtbar und erreichbar macht. 4. Server Message Block. 5. Windows wendet automatisch die zum jeweiligen Profil passenden Firewall-Regeln an, ohne manuelles Eingreifen – praktisch, weil der Laptop im Heimnetz Dateifreigaben nutzen kann, im Café aber automatisch restriktiver geschützt ist.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] lauschende Ports vollständig dokumentiert hast,
- [ ] ein Netzwerkprofil gewechselt und die Wirkung beobachtet hast,
- [ ] die drei Netzwerkprofile und ihre Wirkung erklären kannst,
- [ ] das Risiko von Netzwerkerkennung in öffentlichen Netzen einschätzen kannst.

Kapitel 8: Windows Defender und Virenschutz

Lernziele

- Du prüfst den Defender-Status per PowerShell.
- Du unterscheidest Echtzeitschutz von einem On-Demand-Scan.
- Du bewertest das Risiko von Ausschlüssen (Exclusions).

1. Einführung

Microsoft Defender Antivirus ist seit Windows 8 fest in Windows integriert und seit mehreren Jahren ein vollwertiger, von unabhängigen Testlaboren regelmäßig gut bewerteter Virenschutz, nicht mehr nur ein Basisschutz der zweiten Wahl.

2. Technische Grundlagen

Der **Echtzeitschutz** prüft Dateien fortlaufend beim Zugriff, ein **On-Demand-Scan** prüft gezielt einen angegebenen Pfad bei Bedarf. Defender nutzt zusätzlich Cloud-basierte Schutzfunktionen, die verdächtige, noch unbekannte Dateien zur schnelleren Analyse an Microsoft übermitteln können.

Beispiel 8.1: Defender-Status abfragen

```
PS> Get-MpComputerStatus | Select-Object AntivirusEnabled, `
    RealTimeProtectionEnabled, AntivirusSignatureLastUpdated
```

3. Fachbegriffe

Ein **Exclusion** (Ausschluss) nimmt eine Datei, einen Ordner oder einen Prozess ausdrücklich von der Prüfung durch Defender aus – notwendig für manche Entwicklungs- oder Serverumgebungen, aber ein direktes Sicherheitsrisiko, wenn zu großzügig vergeben. **Cloud-delivered Protection** beschleunigt die Reaktion auf neue Bedrohungen über Microsofts Cloud-Infrastruktur.

4. Praxis und Konfiguration

Beispiel 8.2: On-Demand-Scan starten

```
PS> Start-MpScan -ScanType QuickScan
```

Beispiel 8.3: Aktuelle Ausschlüsse anzeigen

```
PS> Get-MpPreference | Select-Object ExclusionPath, ExclusionProcess
```

Beispiel 8.4: Signaturen manuell aktualisieren

```
PS> Update-MpSignature
```

5. Sicherheitsbetrachtung

> **WARNUNG – Sicherheitsrisiko**
>
> Jeder Ausschluss ist ein bewusst geschaffener, von Defender nicht mehr geprüfter blinder Fleck. Beschränke Ausschlüsse auf das unbedingt Notwendige, dokumentiere jeden einzelnen mit Begründung, und entferne ihn, sobald er nicht mehr gebraucht wird.

6. Praktische Laborübungen

Übung A: Defender-Status prüfen und Testscan durchführen

Aufgabenstellung: Prüfe den vollständigen Defender-Status und führe einen Testscan mit der EICAR-Testdatei durch. **Ausgangssituation:** CLIENT01, Defender aktiv. **Voraussetzungen:** Internetzugang für die EICAR-Datei (öffentlich von eicar.org verfügbar). **Schritt-für-Schritt-Anleitung:** siehe Beispiel 8.1, dann die EICAR-Testdatei herunterladen. **Erwartetes Ergebnis:** Defender erkennt und blockiert die EICAR-Testdatei umgehend, meist schon beim Download (Echtzeitschutz). **Überprüfung:** Eine Sicherheitsmeldung von Defender bestätigt die Erkennung. **Fehleranalyse:** Keine Erkennung? Prüfe mit Beispiel 8.1, ob `RealTimeProtectionEnabled` tatsächlich `True` ist. **Musterlösung:** Eine dokumentierte, erfolgreiche Erkennung der EICAR-Testdatei.

Übung B: Ausschlüsse bewusst anlegen und wieder entfernen

Aufgabenstellung: Lege einen Testausschluss an, bestätige seine Wirkung, und entferne ihn wieder. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** administrative Rechte. **Schritt-für-Schritt-Anleitung:**

Befehle zu Übung B

```
PS> Add-MpPreference -ExclusionPath "C:\Testordner"
PS> Get-MpPreference | Select-Object ExclusionPath
PS> Remove-MpPreference -ExclusionPath "C:\Testordner"
```

Erwartetes Ergebnis: Der Ausschluss erscheint nach dem Hinzufügen und ist nach dem Entfernen nicht mehr vorhanden. **Überprüfung:** `Get-MpPreference` bestätigt beide Zustände. **Fehleranalyse:** Ausschluss bleibt bestehen? Exakten Pfad für `Remove-MpPreference` prüfen. **Musterlösung:** Eine bereinigte Ausschlussliste ohne Testeinträge.

7. Typische Fehler

Fehler	Ursache	Behebung
Ausschluss „aus Bequemlichkeit“ für einen ganzen Ordner statt einer einzelnen Datei	fehlende Eingrenzung	Ausschluss so eng wie möglich fassen
Echtzeitschutz dauerhaft deaktiviert	Fehldiagnose eines Leistungsproblems	Ursache gezielt untersuchen statt Schutz pauschal abzuschalten
Signaturen veraltet	automatische Aktualisierung nicht geprüft	regelmäßig `Get-MpComputerStatus` kontrollieren

8. Zusammenfassung

> **Zusammenfassung**
>
> - Microsoft Defender ist ein vollwertiger, fest integrierter Virenschutz.
> - Echtzeitschutz prüft fortlaufend, On-Demand-Scans gezielt bei Bedarf.
> - Jeder Ausschluss ist ein bewusster, dokumentierter blinder Fleck.
> - Cloud-delivered Protection beschleunigt die Reaktion auf neue Bedrohungen.

9. Kontrollfragen

1. Was prüft der Echtzeitschutz im Unterschied zu einem On-Demand-Scan? (leicht)
2. Welcher Befehl zeigt den Defender-Status? (leicht)
3. Warum ist ein Exclusion ein Sicherheitsrisiko? (mittel)
4. Wie aktualisierst du Defender-Signaturen manuell? (mittel)
5. Eine Anwendung funktioniert angeblich nur mit einem vollständigen Defender-Ausschluss für ihr gesamtes Installationsverzeichnis. Wie gehst du vor, bevor du diesen Ausschluss setzt? (schwer)

Lösungshinweise: 1. Er prüft Dateien fortlaufend beim Zugriff, statt nur gezielt bei Bedarf. 2. `Get-MpComputerStatus`. 3. Weil er einen von Defender nicht mehr geprüften, blinden Fleck schafft. 4. `Update-MpSignature`. 5. Prüfen, ob tatsächlich das gesamte Verzeichnis oder nur eine konkrete, fälschlich blockierte Datei betroffen ist, und den Ausschluss so eng wie möglich auf genau diese Datei statt das ganze Verzeichnis beschränken.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] den Defender-Status per PowerShell geprüft hast,
- [ ] einen Testscan mit der EICAR-Datei durchgeführt hast,
- [ ] einen Ausschluss angelegt und wieder entfernt hast,
- [ ] das Risiko großzügiger Ausschlüsse einschätzen kannst.

Kapitel 9: Windows Defender Firewall

Lernziele

- Du erklärst das profilbasierte Firewall-Modell von Windows.
- Du erstellst eine eingehende Regel per PowerShell.
- Du vergleichst die Konfiguration über GUI, netsh und PowerShell.

1. Einführung

Kapitel 7 hat die drei Netzwerkprofile eingeführt. Dieses Kapitel zeigt, wie die Windows Defender Firewall genau darauf aufbaut und für jedes Profil eigene Regeln vorhält.

2. Technische Grundlagen

Die Windows Defender Firewall verwaltet **eingehende** und **ausgehende** Regeln getrennt für jedes der drei Netzwerkprofile. Standardmäßig blockiert sie eingehende Verbindungen, die keiner expliziten Regel entsprechen – dasselbe Standard-Deny-Prinzip wie bei einer Linux-Firewall.

Beispiel 9.1: Firewall-Status je Profil anzeigen

```
PS> Get-NetFirewallProfile | Select-Object Name, Enabled, DefaultInboundAction
```

3. Fachbegriffe

Eine **Regel** (Rule) definiert, welcher Verkehr (Richtung, Protokoll, Port, Programm) zugelassen oder blockiert wird. `netsh advfirewall` ist das ältere, aber weiterhin unterstützte Kommandozeilenwerkzeug; die PowerShell-Cmdlets (`New-NetFirewallRule` und verwandte) sind der modernere, empfohlene Weg.

4. Praxis und Konfiguration

Beispiel 9.2: Eine eingehende Regel per PowerShell erstellen

```
PS> New-NetFirewallRule -DisplayName "Test-HTTP-Zugriff" -Direction Inbound `
    -Protocol TCP -LocalPort 8080 -Action Allow -Profile Private
```

Beispiel 9.3: Dieselbe Regel mit netsh (Vergleich)

```
PS> netsh advfirewall firewall add rule name="Test-HTTP-Zugriff" dir=in `
    action=allow protocol=TCP localport=8080
```

Gut zu wissen

`netsh` selbst kennt in cmd.exe keine Zeilenfortsetzung über einen rückwärtigen Schrägstrich; das dortige Fortsetzungszeichen ist das Caret `^`. Wird der Befehl, wie hier, aus einer PowerShell-Sitzung heraus aufgerufen (Präfix `PS>`), gilt stattdessen der Backtick als PowerShell-eigenes Fortsetzungszeichen, der den Befehl vor der Übergabe an `netsh` zu einer einzigen Zeile zusammenfügt.

Beispiel 9.4: Regeln auflisten und eine Regel entfernen

```
PS> Get-NetFirewallRule -DisplayName "Test-HTTP-Zugriff"
PS> Remove-NetFirewallRule -DisplayName "Test-HTTP-Zugriff"
```

5. Sicherheitsbetrachtung

> **WARNUNG – Sicherheitsrisiko**
>
> Lege vor Änderungen am Firewall-Profil „Öffentlich“ einen Prüfpunkt an (siehe Vorwort). Eine zu freizügige Regel in diesem Profil bleibt auch in tatsächlich unsicheren Netzen wirksam.

6. Praktische Laborübungen

Übung A: Eine Regel per PowerShell erstellen und testen

Aufgabenstellung: Erstelle die Regel aus Beispiel 9.2 und bestätige ihre Wirkung. **Ausgangssituation:** CLIENT01, Standard-Firewall-Konfiguration. **Voraussetzungen:** administrative Rechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 9.2, 9.4. **Erwartetes Ergebnis:** `Get-NetFirewallRule` zeigt die neue Regel als aktiv. **Überprüfung:** Die Regel erscheint auch in der Firewall-GUI (`wf.msc`) unter „Eingehende Regeln“. **Fehleranalyse:** Regel nicht sichtbar? `wf.msc` neu laden oder PowerShell-Sitzung auf administrative Rechte prüfen. **Musterlösung:** Eine erfolgreich erstellte, über zwei Wege (PowerShell und GUI) bestätigte Regel.

Übung B: Regel nach netsh nachbauen und vergleichen

Aufgabenstellung: Entferne die Regel aus Übung A und baue sie mit `netsh` nach Beispiel 9.3 nach. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** Regel entfernen (Beispiel 9.4), danach Beispiel 9.3 ausführen. **Erwartetes Ergebnis:** Dieselbe Regel erscheint erneut, diesmal über `netsh` erstellt. **Überprüfung:** `Get-NetFirewallRule -DisplayName "Test-HTTP-Zugriff"` zeigt die Regel unabhängig vom Erstellungsweg. **Fehleranalyse:** Regel fehlt? `netsh`-Syntax exakt gegen Beispiel 9.3 prüfen. **Musterlösung:** Eine dokumentierte Bestätigung, dass beide Wege zum selben Ergebnis führen, mit abschließender Entfernung der Testregel.

7. Typische Fehler

Fehler	Ursache	Behebung
Regel versehentlich für alle Profile statt nur „Privat“ erstellt	`-Profile`-Parameter vergessen	Profil immer explizit angeben
Testregel nach der Übung nicht entfernt	Übung nicht vollständig abgeschlossen	Testregeln konsequent wieder entfernen
`netsh` und PowerShell als grundverschieden missverstanden	fehlende Einordnung	beide verwalten dieselbe zugrunde liegende Firewall-Engine

8. Zusammenfassung

> **Zusammenfassung**

- Die Windows Defender Firewall verwaltet Regeln getrennt pro Netzwerkprofil.
- Eingehender Verkehr wird standardmäßig blockiert, sofern keine Regel ihn erlaubt.
- PowerShell-Cmdlets sind der moderne, `netsh` der ältere, weiterhin unterstützte Verwaltungsweg.
- Änderungen am „Öffentlich“-Profil verdienen besondere Vorsicht.

9. Kontrollfragen

1. Für wie viele Netzwerkprofile verwaltet die Firewall getrennte Regeln? (leicht)
2. Welches PowerShell-Cmdlet erstellt eine neue Firewall-Regel? (leicht)
3. Was ist die Standardaktion für eingehenden, nicht ausdrücklich erlaubten Verkehr? (mittel)
4. Was ist der Unterschied zwischen `netsh advfirewall` und den PowerShell-Cmdlets? (mittel)
5. Eine Regel wurde ohne `-Profile`-Angabe erstellt und gilt dadurch für alle drei Profile. Welches konkrete Risiko ergibt sich daraus im „Öffentlich“-Profil? (schwer)

Lösungshinweise: 1. Drei (Öffentlich, Privat, Domäne). 2. `New-NetFirewallRule`. 3. Blockieren. 4. Beide verwalten dieselbe zugrunde liegende Firewall-Engine, PowerShell ist der modernere, empfohlene Weg. 5. Der freigegebene Port bleibt auch in nicht vertrauenswürdigen, öffentlichen Netzen erreichbar, wodurch die eigentlich vorgesehene, restriktivere Schutzwirkung des öffentlichen Profils für genau diesen Port ausgehebelt wird.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] eine Firewall-Regel per PowerShell erstellt hast,
- [ ] dieselbe Regel mit `netsh` nachgebaut hast,
- [ ] das profilbasierte Firewall-Modell erklären kannst,
- [ ] das Risiko einer profilübergreifenden Regel im öffentlichen Netz einschätzen kannst.

Kapitel 10: Windows Updates und Patchmanagement

Lernziele

- Du unterscheidest Feature- von Sicherheitsupdates.
- Du wertest den Update-Verlauf eines Systems aus.
- Du nutzt das PSWindowsUpdate-Modul zur Verwaltung ausstehender Updates.

1. Einführung

Band 1 der Linux-Schwesterreihe zeigt, wie entscheidend zeitnahe Sicherheitsupdates sind. Unter Windows gilt dasselbe Prinzip, mit eigener Terminologie und eigenem Rhythmus.

2. Technische Grundlagen

Microsoft unterscheidet **kumulative Sicherheitsupdates** (monatlich, am Patch Tuesday, beheben bekannt gewordene Schwachstellen) von **Feature-Updates** (größere Versionssprünge, seltener, mit neuen Funktionen). Windows Update verwaltet beide über denselben Mechanismus, aber mit unterschiedlicher Priorität und Dringlichkeit.

Beispiel 10.1: Installierte Updates auflisten

```
PS> Get-HotFix | Sort-Object InstalledOn -Descending | Select-Object -First 10
```

3. Fachbegriffe

Der **Patch Tuesday** ist der zweite Dienstag jedes Monats, an dem Microsoft regulär Sicherheitsupdates veröffentlicht. **Windows Update for Business** (Band 2) erlaubt Unternehmen, Updateverteilung zentral zu steuern, statt sich auf die Standardeinstellungen jedes einzelnen Geräts zu verlassen.

4. Praxis und Konfiguration

Beispiel 10.2: PSWindowsUpdate installieren

```
PS> Install-Module -Name PSWindowsUpdate -Force
PS> Import-Module PSWindowsUpdate
```

Beispiel 10.3: Ausstehende Updates auflisten und installieren

```
PS> Get-WindowsUpdate
PS> Install-WindowsUpdate -AcceptAll -AutoReboot
```

WARNUNG – Sicherheitsrisiko

`-AutoReboot` startet das System nach der Installation automatisch neu. Setze diese Option nicht auf einem produktiv genutzten System ohne vorherige Ankündigung.

5. Sicherheitsbetrachtung

Ein System, das Updates über Monate aufschiebt, sammelt bekannte, öffentlich dokumentierte Schwachstellen an – eines der am leichtesten vermeidbaren, aber in der Praxis häufigsten Risiken, genau wie bei der entsprechenden Betrachtung in der Linux-Schwesterreihe.

6. Praktische Laborübungen

Übung A: Update-Verlauf auswerten

Aufgabenstellung: Werte den Update-Verlauf von CLIENT01 aus und identifiziere das zuletzt installierte Sicherheitsupdate. **Ausgangssituation:** CLIENT01 nach Beispiel V.2, mindestens einmal aktualisiert. **Voraussetzungen:** keine besonderen. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 10.1. **Erwartetes Ergebnis:** Eine Liste der letzten zehn installierten Updates mit Datum. **Überprüfung:** Das Datum des letzten Updates liegt plausibel nahe am aktuellen Zeitpunkt. **Fehleranalyse:** Keine Einträge? Windows Update mindestens einmal manuell ausführen (Einstellungen -> Windows Update -> Nach Updates suchen). **Musterlösung:** Eine dokumentierte Liste mit dem zuletzt installierten Update und seinem Datum.

Übung B: PSWindowsUpdate einsetzen

Aufgabenstellung: Installiere das PSWindowsUpdate-Modul und liste ausstehende Updates auf, ohne sie zu installieren. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** Internetzugang, administrative Rechte. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 10.2, dann nur `Get-WindowsUpdate` ohne Installation. **Erwartetes Ergebnis:** Eine Liste ausstehender, noch nicht installierter Updates. **Überprüfung:** Die Liste stimmt mit der Anzeige in den Windows-Update-Einstellungen überein. **Fehleranalyse:** Modul-Installation schlägt fehl? Prüfen, ob die PowerShell-Gallery erreichbar ist (`Get-PSRepository`). **Musterlösung:** Eine dokumentierte Liste ausstehender Updates, bewusst ohne automatischen Neustart installiert.

7. Typische Fehler

Fehler	Ursache	Behebung
Updates über Wochen aufgeschoben	„nicht jetzt“ wiederholt gewählt	feste Updatezeitfenster einplanen
`-AutoReboot` auf produktivem System genutzt	Testverhalten unreflektiert übernommen	Neustart manuell und angekündigt durchführen
Feature- und Sicherheitsupdate gleich priorisiert	fehlende Unterscheidung	Sicherheitsupdates grundsätzlich zeitnah einspielen

8. Zusammenfassung

Zusammenfassung

- Sicherheitsupdates erscheinen regulär am monatlichen Patch Tuesday, Feature-Updates seltener.
- `Get-HotFix` zeigt den bisherigen Update-Verlauf.
- PSWindowsUpdate erlaubt die gezielte Verwaltung ausstehender Updates per PowerShell.
- Aufgeschobene Sicherheitsupdates sind ein leicht vermeidbares, aber häufiges Risiko.

9. Kontrollfragen

1. Wann erscheinen reguläre Windows-Sicherheitsupdates? (leicht)
2. Welcher Befehl zeigt den bisherigen Update-Verlauf? (leicht)
3. Was unterscheidet ein Feature- von einem Sicherheitsupdate? (mittel)
4. Welches Modul erweitert PowerShell um gezielte Update-Verwaltung? (mittel)
5. Ein Nutzer verschiebt Sicherheitsupdates regelmäßig um mehrere Wochen, „weil der Neustart stört“. Welches konkrete Risiko erklärst du ihm? (schwer)

Lösungshinweise: 1. Am Patch Tuesday, dem zweiten Dienstag jedes Monats. 2. `Get-HotFix`. 3. Ein Sicherheitsupdate behebt bekannt gewordene Schwachstellen, ein Feature-Update bringt neue Funktionen. 4. PSWindowsUpdate. 5. Jede Woche ohne das Update bedeutet eine bereits öffentlich bekannte, unbehobene Schwachstelle, die aktiv ausgenutzt werden kann – der kurzzeitige Neustart wiegt dieses Risiko in aller Regel nicht auf.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] den Update-Verlauf eines Systems ausgewertet hast,
- [ ] ausstehende Updates mit PSWindowsUpdate aufgelistet hast,
- [ ] Feature- und Sicherheitsupdates unterscheiden kannst,
- [ ] das Risiko aufgeschobener Sicherheitsupdates erklären kannst.

Kapitel 11: Windows-Sicherheitsprotokolle

Lernziele

- Du findest fehlgeschlagene Anmeldeversuche im Sicherheitsereignisprotokoll.
- Du kennst die wichtigsten sicherheitsrelevanten Event-IDs.
- Du erstellst eine benutzerdefinierte Ansicht im Event Viewer.

1. Einführung

Ohne Protokollierung bleibt jede Sicherheitsmaßnahme aus den vorherigen Kapiteln unüberprüfbar. Dieses Kapitel macht sichtbar, was Windows dazu bereits von sich aus mitschreibt.

2. Technische Grundlagen

Windows führt mehrere getrennte Ereignisprotokolle, darunter **Sicherheit**, **System** und **Anwendung**, zugänglich über den **Event Viewer** (`eventvwr.msc`) oder per PowerShell über `Get-WinEvent`, das funktionale Pendant zu `journalctl` unter Linux.

Beispiel 11.1: Die letzten zehn Sicherheitsereignisse anzeigen

```
PS> Get-WinEvent -LogName Security -MaxEvents 10
```

3. Fachbegriffe

Eine **Event-ID** identifiziert den Typ eines protokollierten Ereignisses eindeutig. Wichtige Beispiele: **4624** (erfolgreiche Anmeldung), **4625** (fehlgeschlagene Anmeldung), **4648** (Anmeldung mit explizit anderen Zugangsdaten, oft bei `runas` oder lateralem Zugriff relevant).

4. Praxis und Konfiguration

Beispiel 11.2: Fehlgeschlagene Anmeldeversuche gezielt filtern

```
PS> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625} -MaxEvents 20
```

Beispiel 11.3: Eine benutzerdefinierte Ansicht im Event Viewer erstellen

```
eventvwr.msc -> Benutzerdefinierte Ansichten -> Benutzerdefinierte Ansicht erstellen
-> Ereignisprotokoll "Security" -> Event-IDs "4624,4625" eingeben
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Das Sicherheitsereignisprotokoll hat eine begrenzte Größe und überschreibt ältere Einträge, sobald das Limit erreicht ist. Für eine länger zurückreichende Auswertung muss die Protokollgröße angepasst oder eine zentrale Sammlung (Band 2, Sysmon) eingerichtet werden.

Ein Protokoll, das existiert, aber nie ausgewertet wird, schützt niemanden – dieselbe Erkenntnis wie bei der entsprechenden Betrachtung in der Linux-Schwesterreihe gilt hier unverändert.

6. Praktische Laborübungen

Übung A: Fehlgeschlagene Anmeldeversuche auswerten

Aufgabenstellung: Erzeuge absichtlich einige fehlgeschlagene Anmeldeversuche und werte sie aus. **Ausgangssituation:** CLIENT01 mit `testuser` aus Kapitel 3. **Voraussetzungen:** administrative Rechte zur Auswertung. **Schritt-für-Schritt-Anleitung:** Einige falsche Passworteingaben für `testuser` provozieren, danach Beispiel 11.2 ausführen. **Erwartetes Ergebnis:** Jeder Fehlversuch erscheint als eigenes Ereignis mit Event-ID 4625. **Überprüfung:** Die Anzahl der gefundenen Ereignisse stimmt mit den tatsächlichen Fehlversuchen überein. **Fehleranalyse:** Keine Treffer? Prüfen, ob die lokale Überwachungsrichtlinie (`auditpol /get /category:*`) Anmeldeversuche tatsächlich protokolliert. **Musterlösung:** Eine vollständige, mit Zeitstempel versehene Liste der Fehlversuche.

Übung B: Benutzerdefinierte Ansicht erstellen

Aufgabenstellung: Erstelle eine benutzerdefinierte Ansicht nach Beispiel 11.3, die erfolgreiche und fehlgeschlagene Anmeldungen gemeinsam zeigt. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** keine besonderen. **Schritt-für-Schritt-Anleitung:** siehe Beispiel 11.3. **Erwartetes Ergebnis:** Eine gespeicherte Ansicht, die beide Event-Typen gefiltert anzeigt. **Überprüfung:** Die Ansicht bleibt nach einem Neustart des Event Viewers erhalten. **Fehleranalyse:** Ansicht zeigt nichts an? Event-IDs exakt, durch Komma getrennt, ohne Leerzeichen eingeben. **Musterlösung:** Eine funktionierende, gespeicherte, wiederverwendbare Ansicht.

7. Typische Fehler

Fehler	Ursache	Behebung
Protokoll nie ausgewertet	fehlende Routine	regelmäßige, mindestens stichprobenartige Prüfung einplanen
Protokollgröße zu klein für längere Analysen	Standardgröße nie angepasst	Protokollgröße erhöhen oder zentral sammeln (Band 2)
Event-ID 4648 übersehen	weniger bekannt als 4624/4625	gezielt auch auf explizite Anmeldungen mit anderen Zugangsdaten prüfen

8. Zusammenfassung

Zusammenfassung

- Der Event Viewer und `Get-WinEvent` sind die zentralen Werkzeuge zur Protokollauswertung.
- Event-IDs 4624, 4625 und 4648 gehören zu den wichtigsten sicherheitsrelevanten Ereignissen.
- Das Sicherheitsprotokoll hat eine begrenzte Größe und überschreibt ältere Einträge.
- Ein nie ausgewertetes Protokoll bietet praktisch keinen Schutz.

9. Kontrollfragen

1. Welche Event-ID kennzeichnet eine fehlgeschlagene Anmeldung? (leicht)
2. Welcher PowerShell-Befehl liest Ereignisprotokolle aus? (leicht)
3. Was passiert, wenn das Sicherheitsprotokoll sein Größenlimit erreicht? (mittel)
4. Wofür ist Event-ID 4648 ein typischer Hinweis? (mittel)
5. Ein System zeigt viele Einträge mit Event-ID 4625 für dasselbe Konto in kurzer Zeit. Was vermutest du, und was prüfst du als Nächstes? (schwer)

Lösungshinweise: 1. 4625. 2. `Get-WinEvent`. 3. Ältere Einträge werden standardmäßig überschrieben, sofern die Größe nicht angepasst oder zentral gesammelt wird. 4. Eine Anmeldung mit explizit anderen Zugangsdaten, etwa über `runas` oder im Rahmen lateraler Bewegung. 5. Einen möglichen Brute-Force-Versuch; als Nächstes die Quelladresse der Versuche prüfen und gegebenenfalls eine Kontosperrung oder zusätzliche Firewall-Maßnahme in Betracht ziehen.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] fehlgeschlagene Anmeldeversuche gezielt gefiltert hast,
- [ ] eine benutzerdefinierte Ansicht erstellt hast,
- [ ] die wichtigsten sicherheitsrelevanten Event-IDs benennen kannst,
- [ ] die Begrenzung der Protokollgröße als praktische Einschränkung einordnest.

Kapitel 12: Verschlüsselung mit BitLocker

Lernziele

- Du erklärst die Rolle des TPM als Hardware-Vertrauensanker.
- Du aktivierst BitLocker auf einem Testlaufwerk.
- Du sicherst einen Wiederherstellungsschlüssel und simulierst einen Wiederherstellungsfall.

1. Einführung

Dieses letzte Kapitel von Band 1 schließt den Kreis: Ein gestohlenes, unverschlüsseltes Gerät macht jede vorherige Maßnahme zunichte, sobald die Festplatte ausgebaut und in einem anderen System ausgelesen wird.

2. Technische Grundlagen

BitLocker verschlüsselt ein gesamtes Laufwerk und nutzt dabei, wo vorhanden, das **TPM** (Trusted Platform Module) als Hardware-Vertrauensanker: Der Entschlüsselungsschlüssel ist an genau dieses TPM gebunden, sodass eine ausgebaute Festplatte in einem anderen Gerät ohne zusätzliches Wissen nicht lesbar ist.

Beispiel 12.1: BitLocker-Status prüfen

```
PS> Get-BitLockerVolume
```

3. Fachbegriffe

Der **Wiederherstellungsschlüssel** ist ein 48-stelliger numerischer Code, der Zugriff ermöglicht, falls das TPM die normale Entsperrung verweigert (etwa nach Hardwareänderungen). **EFS** (Encrypting File System) verschlüsselt einzelne Dateien oder Ordner benutzerbezogen, im Unterschied zu BitLockers vollständiger Laufwerksverschlüsselung.

4. Praxis und Konfiguration

Beispiel 12.2: BitLocker auf einem Laufwerk aktivieren

```
PS> Enable-BitLocker -MountPoint "D:" -EncryptionMethod XtsAes256 `
    -UsedSpaceOnly -RecoveryPasswordProtector
```

Beispiel 12.3: Wiederherstellungsschlüssel anzeigen und extern sichern

```
PS> (Get-BitLockerVolume -MountPoint "D:").KeyProtector |
    Select-Object KeyProtectorType, RecoveryPassword |
    Out-File -FilePath E:\bitlocker_wiederherstellung.txt
```

Gut zu wissen

Es gibt drei unterschiedliche Wege, einen BitLocker-Wiederherstellungsschlüssel zentral statt nur lokal zu sichern, je nach Umgebung. Für ein eigenständiges System wie CLIENT01 in diesem Band, ohne Domänen- oder Cloud-Anbindung, bleibt nur der manuelle, externe Export, wie in Beispiel 12.3 gezeigt. In einer lokalen Active-Directory-Domäne lässt sich der Schlüssel stattdessen automatisiert im Verzeichnisdienst selbst hinterlegen; dieser Weg wird in Band 2 im Zusammenhang mit Active Directory vertieft. Für ein mit Microsoft Entra ID (vormals Azure AD) verbundenes Gerät existiert zusätzlich das Cmdlet `BackupToAAD-BitLockerKeyProtector`, das aber eine tatsächliche Entra-ID-Registrierung voraussetzt und damit außerhalb des Rahmens dieser Buchreihe liegt. Verwechsle diese drei Wege nicht: Ein Befehl, der für eine Cloud-verbundene Umgebung gedacht ist, schlägt auf einem eigenständigen System wie CLIENT01 fehl.

Beispiel 12.4: Einen Wiederherstellungsfall simulieren

```
PS> manage-bde -unlock D: -RecoveryPassword <48-stelliger Code>
```

5. Sicherheitsbetrachtung

WARNUNG – Sicherheitsrisiko

Sichere den Wiederherstellungsschlüssel niemals ausschließlich auf demselben Gerät, das er schützen soll. Ein ausschließlich lokal gespeicherter Schlüssel ist bei einem gestohlenen Gerät wertlos.

Gut zu wissen

`-UsedSpaceOnly` verschlüsselt nur den tatsächlich genutzten Speicherplatz und ist für neue Laufwerke deutlich schneller als eine vollständige Verschlüsselung; für ein bereits länger genutztes Laufwerk mit potenziell wiederherstellbaren, gelöschten Daten ist eine vollständige Verschlüsselung gründlicher.

6. Praktische Laborübungen

Übung A: BitLocker auf einem Testlaufwerk aktivieren

Aufgabenstellung: Aktiviere BitLocker auf einem zusätzlichen Testlaufwerk (nicht dem Systemlaufwerk). **Ausgangssituation:** CLIENT01 mit einem zusätzlichen, leeren virtuellen Datenträger. **Voraussetzungen:** administrative Rechte, TPM in der VM aktiviert (siehe Kapitel 6). **Schritt-für-Schritt-Anleitung:** siehe Beispiel 12.1, 12.2. **Erwartetes Ergebnis:** `Get-BitLockerVolume` zeigt das Laufwerk als „FullyEncrypted“ oder im Verschlüsselungsvorgang. **Überprüfung:** Der Verschlüsselungsstatus ist über die Zeit fortschreitend und schließt vollständig ab. **Fehleranalyse:** Kein TPM gefunden? Alternative mit `-RecoveryPasswordProtector` ohne TPM-Bindung nutzen, mit entsprechend geringerer Schutzwirkung. **Musterlösung:** Ein vollständig verschlüsseltes Testlaufwerk.

Übung B: Wiederherstellungsschlüssel sichern und Wiederherstellung simulieren

Aufgabenstellung: Sichere den Wiederherstellungsschlüssel außerhalb des Systems und simuliere eine Entsperrung damit. **Ausgangssituation:** Ergebnis aus Übung A. **Voraussetzungen:** wie Übung A. **Schritt-für-Schritt-Anleitung:** Schlüssel mit Beispiel 12.3 auslesen, außerhalb des Systems notieren (z. B. ausgedruckt oder in einem separaten, sicheren Dokument), Laufwerk testweise sperren (`manage-bde -lock D:`) und mit Beispiel 12.4 wieder entsperren. **Erwartetes Ergebnis:** Das Laufwerk lässt sich mit dem gesicherten Schlüssel erfolgreich wieder entsperren. **Überprüfung:** Der Zugriff auf die Laufwerksdaten funktioniert nach der Entsperrung normal. **Fehleranalyse:** Entsperrung schlägt fehl? Den 48-stelligen Code exakt, ohne Übertragungsfehler, gegenprüfen. **Musterlösung:** Eine erfolgreiche, dokumentierte Wiederherstellung mit dem extern gesicherten Schlüssel.

7. Typische Fehler

Fehler	Ursache	Behebung
Wiederherstellungsschlüssel nur lokal gespeichert	fehlendes Bewusstsein für den Diebstahlfall	Schlüssel immer extern sichern
BitLocker ohne TPM-Bindung aktiviert, obwohl TPM vorhanden	Standardparameter nicht geprüft	TPM-gestützten Schutz bevorzugen, wo verfügbar
EFS und BitLocker verwechselt	ähnlicher Zweck, unterschiedlicher Geltungsbereich	EFS für einzelne Dateien, BitLocker für das ganze Laufwerk

8. Zusammenfassung

Zusammenfassung

- BitLocker verschlüsselt ein gesamtes Laufwerk und bindet den Schlüssel, wo möglich, an das TPM.
- Der Wiederherstellungsschlüssel muss außerhalb des geschützten Systems gesichert werden.
- `-UsedSpaceOnly` beschleunigt die Verschlüsselung neuer Laufwerke.
- EFS schützt einzelne Dateien, BitLocker das gesamte Laufwerk.

9. Kontrollfragen

1. Wofür steht TPM? (leicht)
2. Wie viele Stellen hat ein BitLocker-Wiederherstellungscode? (leicht)
3. Warum sollte der Wiederherstellungsschlüssel nicht nur lokal gespeichert werden? (mittel)
4. Was unterscheidet EFS von BitLocker? (mittel)
5. Ein Laptop mit BitLocker-geschützter Festplatte wird im eingeschalteten, entsperrten Zustand gestohlen. Schützt BitLocker die Daten in diesem Fall? Begründe. (schwer)

Lösungshinweise: 1. Trusted Platform Module. 2. 48 Stellen. 3. Weil er bei einem gestohlenen Gerät sonst zusammen mit dem Gerät selbst verloren geht. 4. EFS verschlüsselt einzelne Dateien oder Ordner benutzerbezogen, BitLocker das gesamte Laufwerk. 5. Nein, im entsperrten, laufenden Zustand ist das Laufwerk für das System normal lesbar; BitLocker schützt nur den ausgeschalteten oder gesperrten Zustand des Geräts.

10. Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] BitLocker auf einem Testlaufwerk aktiviert hast,
- [ ] den Wiederherstellungsschlüssel extern gesichert hast,
- [ ] einen Wiederherstellungsfall erfolgreich simuliert hast,
- [ ] erklären kannst, warum BitLocker ein entsperrtes, laufendes System nicht schützt.

Abschlussprojekt Band 1: Sicherer Windows-Arbeitsplatz

Installiere einen frischen Windows-11-Client und implementiere ein grundlegendes Sicherheitskonzept, das alle zwölf Kapitel dieses Bandes zusammenführt:

1. **Benutzerkonzept:** ein eingeschränktes Alltagskonto, ein separates administratives Konto, minimal besetzte Administratoren-Gruppe (Kapitel 3-4).
2. **Berechtigungen:** ein Projektordner mit NTFS-Rechten für eine eigens angelegte Gruppe (Kapitel 5).
3. **UAC:** auf der empfohlenen Standardstufe belassen und begründet (Kapitel 4).
4. **Windows Defender:** Echtzeitschutz aktiv, keine unbegründeten Ausschlüsse (Kapitel 8).
5. **Firewall:** Profile korrekt zugeordnet, nur benötigte Regeln aktiv (Kapitel 7, 9).
6. **BitLocker:** mindestens ein Laufwerk verschlüsselt, Wiederherstellungsschlüssel extern gesichert (Kapitel 12).
7. **Dokumentation:** eine zusammenhängende, schriftliche Übersicht aller getroffenen Maßnahmen samt Begründung, als Grundlage für das in Band 2 vertiefte Hardening.

Dieses Projekt bildet den Ausgangspunkt für Band 2, in dem derselbe Client in eine Active-Directory-Domäne eingebunden und professionell weiter gehärtet wird.

Verzeichnis der Befehlsbeispiele

Beispiel V.1: Netzwerkkonfiguration dieses Bandes … Seite 7
Beispiel V.2: CLIENT01 einrichten (Kurzübersicht) … Seite 8
Beispiel 1.1: Schutzebenen eines Windows-Clients (Konzept) … Seite 9
Beispiel 1.2: Grundlegende Systeminformationen abrufen … Seite 9
Beispiel 1.3: Installierte Software auflisten … Seite 10
Befehle zu Übung A … Seite 25
Beispiel 2.1: Dienste und ihren Ausführungskontext anzeigen … Seite 12
Beispiel 2.2: Einen Registry-Schlüssel sicher auslesen … Seite 12
Beispiel 2.3: Laufende Prozesse und ihren Besitzer anzeigen … Seite 12
Befehle zu Übung B … Seite 32
Beispiel 3.1: Lokale Benutzer und Gruppen anzeigen … Seite 15
Beispiel 3.2: Einen lokalen Benutzer und eine Gruppe anlegen … Seite 15
Beispiel 3.3: Mitgliedschaft in der Administratoren-Gruppe prüfen … Seite 16
Beispiel 4.1: Aktuelles Token und Mitgliedschaft prüfen … Seite 18
Beispiel 4.2: UAC-Stufe über die lokale Sicherheitsrichtlinie einsehen … Seite 18
Beispiel 4.3: UAC-Stufe per PowerShell/Registry auslesen … Seite 18
Beispiel 5.1: NTFS-Rechte eines Ordners anzeigen … Seite 21
Beispiel 5.2: NTFS-Rechte gezielt setzen … Seite 21
Beispiel 5.3: Effektive Berechtigungen eines Benutzers prüfen (GUI) … Seite 22
Beispiel 6.1: Aktuelle Anmeldesitzung anzeigen … Seite 24
Beispiel 6.2: Credential Manager einsehen … Seite 24
Beispiel 6.3: Gespeicherte Zugangsdaten per PowerShell auflisten … Seite 24
Beispiel 6.4: Windows Hello einrichten … Seite 24
Beispiel 7.1: Aktuelles Netzwerkprofil anzeigen … Seite 28
Beispiel 7.2: Lauschende Ports und zugehörige Prozesse anzeigen … Seite 28
Beispiel 7.3: Prozessnamen zu einer gefundenen PID auflösen … Seite 28
Beispiel 7.4: Netzwerkprofil eines Adapters ändern … Seite 28
Beispiel 8.1: Defender-Status abfragen … Seite 31
Beispiel 8.2: On-Demand-Scan starten … Seite 31
Beispiel 8.3: Aktuelle Ausschlüsse anzeigen … Seite 31
Beispiel 8.4: Signaturen manuell aktualisieren … Seite 31
Beispiel 9.1: Firewall-Status je Profil anzeigen … Seite 34
Beispiel 9.2: Eine eingehende Regel per PowerShell erstellen … Seite 34
Beispiel 9.3: Dieselbe Regel mit netsh (Vergleich) … Seite 34
Beispiel 9.4: Regeln auflisten und eine Regel entfernen … Seite 35
Beispiel 10.1: Installierte Updates auflisten … Seite 37
Beispiel 10.2: PSWindowsUpdate installieren … Seite 37
Beispiel 10.3: Ausstehende Updates auflisten und installieren … Seite 37
Beispiel 11.1: Die letzten zehn Sicherheitsereignisse anzeigen … Seite 40
Beispiel 11.2: Fehlgeschlagene Anmeldeversuche gezielt filtern … Seite 40
Beispiel 11.3: Eine benutzerdefinierte Ansicht im Event Viewer erstellen … Seite 40
Beispiel 12.1: BitLocker-Status prüfen … Seite 43
Beispiel 12.2: BitLocker auf einem Laufwerk aktivieren … Seite 43
Beispiel 12.3: Wiederherstellungsschlüssel anzeigen und extern sichern … Seite 43
Beispiel 12.4: Einen Wiederherstellungsfall simulieren … Seite 44

Index

Active Directory – 7
BitLocker – 43, 44, 45, 46
Credential Manager – 24, 25, 26, 27
EFS – 43, 45
Event Viewer – 40, 41
Firewall – 7, 9, 10, 11, 28, 29, 30, 34
icacls – 22, 23
Kerberos – 7, 24
NTFS – 11, 21, 22, 23, 46
NTLM – 24
Patch Tuesday – 9, 11, 37, 39
PowerShell – 7, 8, 10, 11, 13, 14, 16, 17
Registry – 12, 13, 14, 18
SID – 15, 17
SMB – 28, 30
Token – 18, 19, 20
TPM – 26, 43, 44, 45
UAC – 18, 19, 20, 46
Windows Defender – 11, 34, 46
Windows Hello – 24, 26, 27

WINDOWS SECURITY BAND 1: GRUNDLAGEN

Vom Standardclient zur eigenen, abgesicherten Konfiguration

Band 1 einer dreibändigen Fachbuchreihe über Windows-Sicherheit unter Windows 11. Zwölf Kapitel führen von der Systemarchitektur über Benutzerkonten, UAC und NTFS-Berechtigungen bis zu Defender, Firewall, Updates, Protokollierung und BitLocker. Jedes Kapitel folgt derselben Struktur: Einführung, technische Grundlagen, Fachbegriffe, Praxis mit PowerShell, Sicherheitsbetrachtung, zwei vollständige Laborübungen, typische Fehler, Zusammenfassung, Kontrollfragen und Lernzielkontrolle.

DAS ERWARTET DICH

- Systemarchitektur, Benutzerkonten, Gruppen und UAC fundiert erklärt
- NTFS-Berechtigungen, Vererbung und effektive Rechte mit icacls
- Windows Defender und Defender Firewall per GUI und PowerShell
- Updates, Sicherheitsprotokolle (Event-IDs) und BitLocker-Verschlüsselung
- 24 vollständige Laborübungen auf Windows 11, mit Musterlösungen und Kontrollfragen

Für wen?

Leser:innen mit Grundkenntnissen der Windows-Bedienung, die systematisch verstehen wollen, warum Sicherheitsmaßnahmen notwendig sind. Grundlage für Band 2 (Active Directory & Hardening) und Band 3 (Analyse und Ethical Hacking).

47 Seiten · Stand Oktober 2026 · Band 1 von 3 · Windows 11 Pro

Hinweis: Keine Rechts- oder Anlageberatung. Marken- und Produktnamen gehören ihren jeweiligen Inhabern.